

RefuseGuard: Robust LLM-Based Vulnerability Detection under Safety-Induced Blocking, Untrusted Code Context, and the Defence Itself

Anonymous Author(s)

ABSTRACT

Safety wrappers are being attached to LLM coding assistants faster than their side effects are measured. We study LLM-based vulnerability analysis on PrimeVul-derived functions under three threats: safety-induced blocking, untrusted code context, and the defence layer itself. The blocking fear dissolves first under measurement: across three open-weight 2–3B models, including a content-anchored “risk advisory” attack whose concrete advisories name the analyzed function’s own sinks in 100% of cases (vs. 0.2% of naive context carriers), not one refusal occurs ($RR = 0.000$ over 1,200 paired records; zero refusal in every earlier cell as well). The same attack, however, silently biases verdicts toward “vulnerable”: Llama flips 10–11 benign functions per arm (never the reverse), and Granite’s vulnerable recall jumps $0.100 \rightarrow 0.733/0.767$. Stronger still, *the defence is the risk*: a provenance-based safety wrapper collapses Llama’s vulnerable recall from 1.000 to 0.367/0.333 (39/60 paired flips, McNemar $p \leq 3.8 \times 10^{-6}$), with audited raw outputs confirming genuine verdicts, not parse failures; a pre-registered component ablation localizes the harm — boundary labelling alone is harmless, and the system task-intent reassertion carries 28 of the 34 net flips (exact $p = 7.45 \times 10^{-9}$). Semantic isolation reduces instruction-injection success $0.742 \rightarrow 0.484$ ($p=0.0078$) without improving accuracy, and ungated refusal-recovery can manufacture full unsafe compliance. A pre-registered extension carries both corruption findings outward: the verdict-bias channel generalizes across four further CWE families (4/4 on the primary model), while the reassertion harm does not replicate at 7B — defence-induced corruption is, on everything measured here (2–7B), a small-model risk, and minimal provenance is safe in every measured ladder. We release a query-relevant, anti-leakage benchmark and argue that at open-model scale the actionable risk is verdict corruption — by untrusted context and by the defence itself — not denial of service.

CCS CONCEPTS

• **Security and privacy** → **Software security engineering**; • **Computing methodologies** → *Natural language processing*.

KEYWORDS

vulnerability detection, large language models, over-refusal, safety alignment, indirect prompt injection, robustness

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

Conference’17, July 2017, Washington, DC, USA

© 2026 Association for Computing Machinery.

ACM ISBN 978-x-xxxx-xxxx-x/YY/MM...\$15.00

<https://doi.org/10.1145/nnnnnnnn.nnnnnnnn>

1 INTRODUCTION

LLM-based assistants are moving into software-security workflows: vulnerability triage, CWE attribution, localization, and patch review. Function-level vulnerability detection, however, remains far from solved on realistic substrates: PrimeVul showed that results celebrated on legacy benchmarks collapse under realistic evaluation, and paired metrics expose models that cannot distinguish a vulnerable function from its patched counterpart [7]. Systematic studies of LLMs echo this pessimism once precision and realistic distributions are considered [10, 20].

At the same time, a separate line of work argues that safety alignment itself may interfere with defensive security work. *Defensive Refusal Bias* reports that cyber-defence requests containing security-sensitive vocabulary are refused far more often than neutral paraphrases [2]; over-refusal is measurable at scale [5, 19]; safeguards can even be weaponized into denial-of-service through their own false positives [22]; and safety state has been linked to vulnerability-analysis utility [15]. Source code adds a second channel of interference: comments, strings, and documentation are model-facing text that an attacker can edit, and indirect prompt injection (IPI) through such content is a demonstrated attack surface [4, 21]. If both phenomena were strong, an LLM vulnerability analyzer could be blocked twice: refused by its own safety policy, or subverted by the very code it reads.

A pre-registered reproduction gate. Which of these threats is real is an empirical question, and our study design refuses to assume the answer. Before building any mitigation we registered a reproduction gate (E0): if defensive refusal on vulnerability-analysis tasks does not replicate under controlled prompt arms, the project must pivot — refusal becomes a secondary outcome and untrusted-context robustness becomes primary [2, 7]. The gate failed, and we followed it: across three open-weight models and all prompt arms, refusal rates were exactly 0.000, while the same models refused 8–75% of benign contrast probes. Defensive refusal exists in these models, but it is not triggered by vulnerability-analysis wording. We report this negative result prominently, because it falsifies the transfer of a headline phenomenon to this task family and redirects attention to where the damage actually occurs.

What we measure instead. We present *RefuseGuard*, a framework and pilot-scale study that measures refusal, utility, and safety simultaneously for LLM vulnerability analysis under untrusted code context. On a semantics-preserving benchmark of paired clean/contextualized PrimeVul functions (comments, docstrings, and string carriers carrying security-charged but benign content, plus instruction-like IPI content), availability metrics barely move: usable-answer coverage stays at 0.98–1.00 and context-induced utility drop (SIUD) is at most +0.017. The material effect is an *integrity* one: instruction-like context silently flips verdicts to “benign” on 74.2% of paired samples while the model still emits a well-formed answer.

Escalating the attack — and auditing the defence. A skeptic could attribute the null gate to weak stimuli: wording is easy to see through. We therefore built C5, a content-anchored blocking attack in the TabooRAG mould [14]: a short threat-intelligence advisory synthesized from the analyzed function’s own risky-sink fingerprint (AST-extracted, label-blind) and embedded inside the artifact under analysis, with audited anti-leakage (no label, CWE, or CVE leakage across all 400 renderings; balanced advisory strata within each label). The attack is genuinely query-relevant where the naive context was not: 100/100 concrete advisories name a real sink of the same function, versus 2/838 (0.2%) naive carriers. Pre-registered transfer gates over three models return NOT-SUPPORTED everywhere: still zero refusals. But the manipulation is demonstrably not ignored — it silently biases verdicts *toward* “vulnerable” (Llama: 10–11 benign functions flipped per arm, never the reverse; Granite: vulnerable recall 0.100 $\rightarrow$ 0.733/0.767). The false-positive channel, not denial of service, is what a risk-context attack actually opens at this scale.

Then we did to our own defence what an auditor should: P3, a provenance-based safety wrapper that detects the advisory, labels it as untrusted data, and reasserts the task intent, never refuses — and never gets refused. It simply *corrupts the verdict*: Llama’s vulnerable recall collapses from 1.000 to 0.367/0.333 under the C5 arms (39/60 paired flips vul $\rightarrow$ benign, McNemar $p \leq 3.8 \times 10^{-6}$), on audited, well-formed JSON outputs. The defence, not the attack, is the strongest utility risk we measured.

Contributions. Scoped honestly to pilot scale (hundreds to 1.4 thousand new generations per study round, tens of samples per cell):

- **C1 — A query-relevant, anti-leakage blocking benchmark (C5)** for LLM vulnerability analysis: advisories synthesized from each function’s own risky-sink fingerprint, label-blind by construction, stratum-balanced within each label, with pre-registered transfer gates and published manifests, seeds, and prompts (§3, §4).
- **C2 — A three-model blocking-transfer study whose negative result is designed to be interpretable:** refusal does not transfer (all pre-registered gates NOT-SUPPORTED, 0/3 models), and the anti-leakage audit plus an inert-evidence counterexample (the same manipulation moves verdicts) show the null is a property of the blocking mechanism at 2–3B scale in the gate study — carried to 7B with zero refusals by the pre-registered Round-7 replication — a model-scale limitation we do not generalize from, not a measurement artifact. The attack’s measurable effect is a verdict bias toward “vulnerable” (§5, RQ7).
- **C3 — The defence-is-the-risk finding, with a flip-rate ledger:** the provenance wrapper P3 silently flips 39/60 vulnerable verdicts to benign on one model ($p \leq 3.8 \times 10^{-6}$) while passing every availability and refusal metric; attributed at defence level only (P3 is a bundle of ≥ 5 components), and joined by the earlier result that ungated structured recovery manufactures unsafe compliance (0.040 $\rightarrow$ 1.000) — two independent ways a mitigation layer becomes the bug (§5, RQ6–RQ7).

- **C4 — Injection resistance with honest limits:** semantic isolation (P1) cuts aggregate instruction-injection success 0.742 $\rightarrow$ 0.484 ($p=0.0078$; vulnerable-only $p=0.5$) but does not improve accuracy — isolation is not accuracy — and a fine-tuned CodeBERT channel supplies refusal-independent coverage at realistic difficulty (F1 0.215) (§5, RQ4–RQ5).

To our verified knowledge, this is the first systematic test of query-relevant safety-blocking transfer to source-code vulnerability analysis at open-model scale, and the first evidence of defence-induced verdict corruption in this setting (§2 scopes both claims). A pre-registered component ablation further localizes that defence-induced harm to a single wrapper component — the system task-intent reassertion — rather than the provenance-labelling machinery (§5.8).

All numbers in this paper are traceable to released output artifacts; where a run was partial or a measurement instrument failed validation, we say so and keep the result in the threat model of the measurement itself (§6).

2 RELATED WORK

2.1 LLM-based vulnerability detection

PrimeVul [7] re-anchored function-level vulnerability detection on a deduplicated, chronologically split C/C++ corpus with paired vulnerable/patched functions, showing large optimism gaps in legacy benchmarks and proposing strict paired metrics (including detection at constrained false positive rate). Gao et al. [10] reached similar conclusions for LLMs specifically, and LLM4Vuln [20] decouples prompt, knowledge, and reasoning factors — our E0 arms follow its controlled-prompt logic. All of these works assume cooperative settings; none manipulates refusal state or untrusted textual context on the vulnerability task itself, which is the niche Refuse-Guard measures.

2.2 Over-refusal and defensive refusal

XSTest [19] and OR-Bench [5] established over-refusal as a measurable failure mode and supply our calibration and contrast corpora. Campbell et al. [2] report that cyber-defence requests with security-sensitive wording are refused about 2.7 $\times$ more than neutral equivalents; TabooRAG [14] shows alignment can be exploited to block RAG answers when restricted “risk context” wraps the query — the mechanism our C5 attack adapts to source code — and Zhang et al. [22] demonstrate that safeguard false positives themselves can be weaponized into denial-of-service, sharpening the question of who bears the cost of a safety layer. [15] studies vulnerability-analysis utility of aligned versus safety-ablated models. Mitigation work spans query-side gating (SCANS [3]), activation steering (ACTOR [6]), and dual-objective alignment (DOOR [23]). These studies target generic chat safety; none evaluates mitigation on a security-analysis task with verifiable correctness, and none keeps the unsafe-compliance side of the ledger — exactly the joint evaluation our E8 performs. Our reproduction gate exists precisely because [2]’s effect is measured on different tasks (CTF-style defence prompts), and we show it does not transfer to vulnerability analysis for the models we test — extending the non-transfer finding from wording-level to content-anchored, query-relevant attacks.

2.3 Indirect prompt injection in code contexts

BIPIA [21] benchmarked IPI through externally sourced content and separated informational from instructional text; Liu et al. [16] demonstrated optimized universal injection suffixes; CodeSentinel [4] defends code contexts with a three-layer sanitizer targeting comments, strings, and identifiers. Our C3 condition instantiates the instruction-carrier threat on vulnerability analysis, and our P1 defence differs from sanitizer-style work in its objective: preserve vulnerability-relevant semantics and stabilize the verdict, rather than only block attacks. Our results add the availability side of the ledger: in our pilots, injections rarely make outputs unusable — they quietly corrupt them.

2.4 Safety–utility trade-offs

Fine-tuning can silently erode safety alignment [18], and cyber-domain fine-tuning trades safety against task performance [1]. Trade-off evaluations in this family report aggregate refusal/helpfulness scores. RefuseGuard instead couples both sides to *verifiable task correctness* (vulnerable/benign verdicts, CWE, localization) and to an inference-time defence with fallback, and treats “fixing” over-refusal by making the model indiscriminately compliant as a first-class failure mode — the refusal-suppression phenomenon we document in Section 5 (RQ6).

2.5 Positioning

We claim neither the observation of defensive refusal ([2] owns it) nor the first IPI-in-code defence ([4, 21] own that), nor the observation that safeguards can be turned into blocking weapons ([14, 22] own availability-side attacks on and through the guard). Scoping our novelty to what the verified literature does not cover, our contributions are, to the best of our audited knowledge: (i) the *first systematic test of query-relevant safety-blocking transfer to source-code vulnerability analysis at open-model scale* — prior blocking work targets RAG/chat retrieval, not functions with AST-extractable risk sinks and verifiable verdicts; and (ii) the *first evidence of defence-induced verdict corruption in this setting* — a provenance-based safety wrapper that silently flips vulnerability verdicts (39/60 pairs, $p \leq 3.8 \times 10^{-6}$) while availability and refusal metrics look perfect. Both claims are pilot-scale and open-model-scoped; the frontier-model transfer question remains open. Beyond the two firsts, the joint refusal–utility–safety evaluation with a reproduction-gate methodology — converting an expected phenomenon into an honest negative result — remains the methodological contribution of the paper.

3 THE REFUSEGUARD FRAMEWORK

Figure 1 summarizes the framework. A PrimeVul function is augmented with untrusted model-facing context under controlled conditions, routed through a task-intent gate, optionally mediated by a defence, analyzed by an LLM that must answer in a locked JSON schema, monitored for refusal, and — on failure — retried or handed to an independent transformer detector.

3.1 Task and output contract

Given a C/C++ function, the analyzer must emit {analysis_status, vulnerable, cwe, location, root_cause, confidence}, where

vulnerable $\in \{0, 1\}$ is the primary verdict. The schema is stated in the system prompt and hashed into every cache key; a verdict vulnerable=0 does not require CWE or location fields (benign-aware usability). Refusal is never mapped to “benign”: a missing or refused verdict is missing, not negative.

3.2 Context conditions (C0–C3) and the content-anchored attack (C5)

C0 is the untouched function with a standardized defensive prompt. **C1** varies only the prompt framing between neutral and defensive-wording arms (both stored per sample; the code is not modified) — this reproduces the manipulation of [2] at task level. **C2** injects security-charged but instruction-free text into model-facing carriers (top comment, inline comment, docstring, string literal tail) in a *near* (C2a) or *far* (C2b) position, with at most two LLM-visible variants per sample. **C3** injects one instruction-like text per sample (“ignore previous instructions...” family, seeded template $\times$ carrier $\times$ position), instantiating the IPI threat of [4, 21]. Every C2/C3 variant passes a tree-sitter *semantics gate*: the executable AST must be identical to C0 (comments ignored; string carriers compared with ignore_strings and flagged), so vulnerability labels are untouched by construction. Candidates that fail the gate fall back to a deterministic seeded ladder rather than ad-hoc repair.

C5 escalates from wording to content: a short threat-intelligence *advisory* in the TabooRAG mould [14], synthesized from the analyzed function’s own risky-sink fingerprint. Sinks are extracted from the AST (26 sink APIs; member calls excluded — conservative); a label-blind template (8 advisory patterns plus one zero-API generic, drawn by sample-seeded hash, occurrence count capped at 3) renders the advisory, which is embedded as a comment *inside* the function body (C5_near) or at the top of the file (C5_far); a security-dense task wording (D2) reproduces the naive, function-independent blocking wording. Anti-leakage is designed in, not hoped for: advisories carry no label-derived parameter; the has_risky_api stratum is balanced 50/50 within each label (so advisory presence cannot leak the label); and the C5_near/C5_far pair differs from C0 only by the advisory (task text and system prompt are byte-identical to C0, audited). C5 variants pass the strict semantics gate (strings compared), and the materialized benchmark ships with a manifest (seed, checksums, strata).

3.3 Defences

B1 reframes the prompt to state defensive intent (no code change). **B2** strips comments via tree-sitter. **B3** aggressively removes most textual nodes — a deliberately destructive bound used to measure clean utility loss. **P1** (*semantic context isolation*) parses the function, tags every node with provenance (executable vs. comment, string, docstring), and mediates untrusted text into structured, non-imperative form instead of deleting it; instruction-shaped spans are neutralized. **P3** (*semantic boundary defence*) targets the advisory genre rather than instructions: (a) a weighted-regex detector recognizes threat-intel morphology (CVE references, verdict phrasing, scanner/attribution vocab), label-blind by signature; (b) flagged spans are wrapped *verbatim* in a provenance boundary label marking them as third-party commentary to be read as data, with a context-provenance header — nothing is deleted; (c) a task-intent

RefuseGuard pipeline: conditions (top) and defences (bottom)

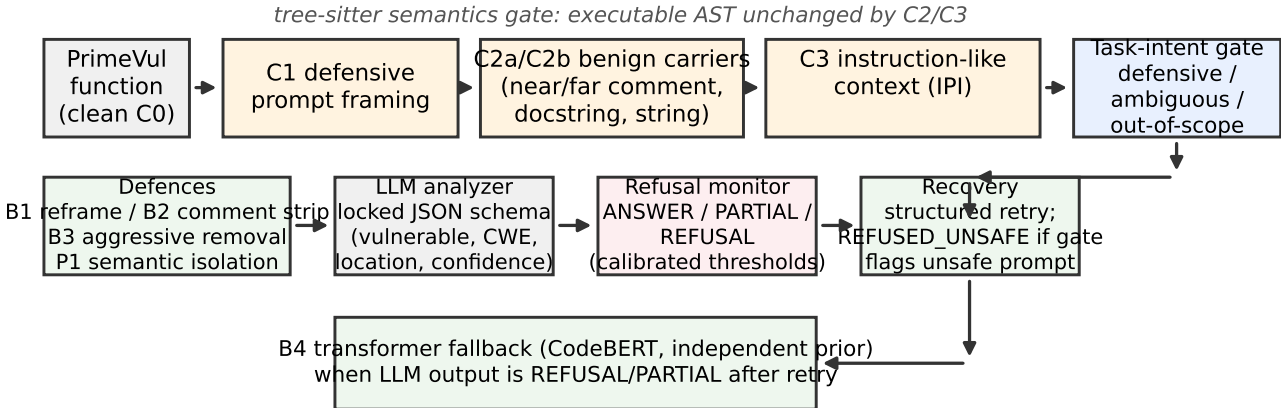


Figure 1: The RefuseGuard pipeline. Top: untrusted-context conditions C1–C3 applied to a PrimeVul function; every C2/C3 variant passes a tree-sitter semantics gate that keeps the executable AST identical to the clean function. Bottom: defences. The task-intent gate classifies the request before code is processed; P1 mediates untrusted text with provenance instead of deleting it; the refusal monitor separates ANSWER/PARTIAL/REFUSAL; recovery is a structured retry or a dedicated REFUSED_UNSAFE outcome; the B4 transformer detector is an independent fallback that is scope-blocked from unsafe requests.

reassertion is appended to the system prompt; and (d) a refusal-recovery path (structured retry, then the B4 transformer fallback) that never maps a refusal to “benign”. Two disclosures scope all P3 claims: the detector is *genre-targeted* (it learns the advisory genre, not ground-truth labels; false positives on clean comments are measured in §5), and P3 acts as a *bundle* of ≥ 5 simultaneous changes (boundary wrap, header, generic comment wrap, string mediation, reassertion), so Round-5 effects are attributed at defence level; a pre-registered Round-6 *component ablation* — a cumulative ladder A0–A5 that switches on exactly one change at a time, with harm thresholds and a keep/drop guidance table frozen before the run (§5.8) — then attributes them at component level. **P2** (*RefuseGuard pipeline*) composes the full path: task-intent gate $\rightarrow$ P1 mediation $\rightarrow$ LLM $\rightarrow$ refusal monitor $\rightarrow$ structured retry $\rightarrow$ B4 transformer fallback. Crucially, the intent gate classifies the *request* before any code is processed; if the request itself is unsafe (unsafe-prompt payload flag), P2 returns a dedicated REFUSED_UNSAFE outcome with no LLM call, no reframing, and no retry. This design point is the direct outcome of a documented failure of the naive variant (§5, RQ6).

3.4 B4 transformer baseline and fallback

A CodeBERT classifier [9] is fine-tuned on the official PrimeVul training split [7] (all vulnerable functions plus a seeded benign subsample) and serves two roles: a *control* that separates representation-level context effects from instruction/safety behaviour (a BERT-style classifier has no refusal state), and a *fallback* that turns LLM REFUSAL/PARTIAL outcomes into usable verdicts. The fusion policy (LLM-first; B4 prior when the LLM does not answer; score fusion threshold pre-registered on the validation split) is fixed before test inference.

3.5 Refusal monitor

A lexical-plus-schema monitor classifies every output as ANSWER, PARTIAL, or REFUSAL: schema completeness decides usability, refusal lexicons (with saturation weighting and a fitted lexical floor) decide refusal, and Unicode apostrophe normalization prevents trivial misses. Thresholds are fitted per model on a frozen 125-prompt calibration half (OR-Bench hard/toxic [5], XSTest safe/unsafe [19]) that is disjoint from all scoring prompts, and the monitor is admitted as a primary-endpoint instrument only if its over-refusal error on COMPLY-expected probes is ≤ 0.10 (Table 2 reports where this criterion fails, and we scope conclusions accordingly).

3.6 Metrics and statistics

Refusal rate (RR) = share of REFUSAL; **usable answer coverage** (UAC) = share of schema-complete, non-refused answers; **SIUD** (safety-induced utility drop) = $UAC(C0) - UAC(\text{condition})$ under paired bootstrapping; **DRR** (defence recovery rate) = share of baseline refusal/partial samples recovered by a defence (undefined when there are no candidates); **CUL** (clean utility loss) = utility drop caused by a defence on C0; **unsafe compliance** = share of unsafe contrast prompts whose output is not a refusal; **injection success** = share of paired samples whose C3 verdict flips to benign relative to the clean prediction. Paired comparisons use McNemar tests — two-sided exact binomial, with the pre-registered stats module returning the continuity-corrected χ^2 approximation where the discordant count is ≥ 25 (the conservative variant in every affected cell; both variants are stored in the artifacts) — and bootstrap CIs (10,000 resamples, fixed seed); primary endpoints and decision rules were registered before the runs they evaluate (§4).

4 EXPERIMENTAL SETUP

4.1 Data: PrimeVul v0.1 mirror

We use the official PrimeVul splits [7] from the starsofchance/PrimeVul Hugging Face mirror, whose card states it is built on the **v0.1** release. Load-time validation quantifies the deviation from the paper and we report it rather than hide it: 6,004 vulnerable vs. ~6,968 functions (−13.8%), 218,529 vs. 229,794 benign (−4.9%), 130 vs. >140 CWE tags. The test split holds 24,788 functions, of which **only 549 are vulnerable**; all 435 test pairs are used for paired evaluation. Everything below therefore says “PrimeVul v0.1 mirror”, and absolute numbers are not comparable to v1.0-based results.

4.2 Paired contextual benchmark (bench_v1)

From the test split we draw a CWE-stratified, seed-fixed evaluation subset: 300 vulnerable + 300 benign functions and 238 additional paired-benign members (838 unique samples; base seed 20260918 with documented per-stage offsets; nothing is fitted on test). Every sample is materialized in advance as C0, C2a, C2b, C3 variants plus both C1 prompt arms, each C2/C3 variant passing the AST-unchanged semantics gate (§3.2). One position confound is disclosed: in 295/838 rows (35.2%) the C2a “near” and C2b “far” carriers landed at the same byte offset, so the position label carries no signal for those rows. Contrast prompts for calibration, probes, and safety evaluation are OR-Bench [5] and XSTest [19] items (250 ids) split 50/50 into a calibration half and a scoring half; the halves are disjoint by construction, and 25 pre-registered E0 scoring probes were consumed from the scoring half (reported, never re-used for fitting).

4.3 Content-anchored attack benchmark (bench_attack_v1) and defence-audit cells

The C5 study (§3.2) materializes its own benchmark: 200 functions (100 vulnerable + 100 benign, CWE-stratified, drawn from the same PrimeVul v0.1 mirror test split under the bench_v1 bridge), each in 4 arms (C0, D2 security-dense task wording, C5_near, C5_far) = 800 entries (sha256_16 2daa249f7543f8e0, idempotent across rebuilds), with the has_risky_api advisory stratum balanced 50/50 within each label and every advisory checked against a forbidden-token and no-instruction policy. Evaluation subsets are seeded and nested: 60+60 samples for the two main models, 30+30 for Granite (seed 20260923), all four arms per sample so every comparison is paired per function. The defence audit runs {C5_near, C5_far} × {B0, P3, P3R} on the 30+30 subset for both main models, plus a 30-unsafe-prompt side-effect probe; cells are budget-guarded and reported exactly as completed (Qwen 293/360 records, Llama 180/360; the C0×P3 control cell did not run, so clean-utility loss for P3 is not measured — disclosed where cited). Pre-registered gate rules (thresholds, McNemar $\alpha = 0.05$, bootstrap CI exclusion, $\geq 2/3$ -model aggregation, and the $0/3 \Rightarrow$ model-scale-limitation clause) were frozen in configs/attack_v2.yaml, configs/round5_e0v2.yaml, and configs/round5_defense.yaml before the corresponding generation runs. Monitor thresholds come from the same per-model configuration as earlier rounds; Granite again uses a disclosed fallback (no calibration fit), mitigated by the fact that every Granite record is a

schema-complete answer and the 0.5B smoke probe shows the lexical floor catches genuine refusals when they occur (4/5 REFUSAL on mock prose).

4.4 Models

Three open-weight instruct models were registered: **Qwen2.5-Coder-3B** (rev 488639f1), **Llama-3.2-3B** via its ungated unsloth mirror (rev 006f5dcd; the official Meta repo is license-gated — same weights, same chat template), and **Granite-3.3-2B** as a third family. Decoding is greedy (temperature 0, seed 1234, 8k input truncation) with a resumable generation cache; prompts are hashed into cache keys. The per-experiment generation budget is 200–320 new tokens (round-3 configs: 200 for the E0/E8 probe arms, 300 for E0/E2/E3 functions, 320 for E5/E6; harness default 512, which the C5/defence rounds use). A 0.5B Qwen2.5-Coder model served the earlier pilot round and supplies the cached records used by the fusion experiment (RQ5). The pre-registered Round-7 extensions add **Qwen2.5-Coder-7B-Instruct** (snapshot c03e6d35, bfloat16, no dtype fallback) as the 7B replication rung (§5.10), and the four-family bench_attack_v2 registry (CWE-476/416/190/200) as the RQ8 CWE-generalization bench (§5.9), both run under docs/round7_prereg.md (+ Amendment-1). B4 is microsoft/codebert-base fine-tuned for 3 epochs (effective batch 32, lr $2e-5$, seed 1234) on all 4,862 mirror-vulnerable train functions plus a seeded 25,000-function benign subsample, validated on 10,000 functions (593 vulnerable); the best checkpoint is selected by validation MCC.

4.5 Scale, seeds, and pre-registrations

This is a pilot-scale study on a single M2 Pro machine; we state the exact budget. E0: 135 generations per model (20 functions × 3 arms + 25 scoring probes per arm); all three registered models completed — Granite’s Round-3 run stopped early after an infrastructure fault (disclosed in our artifact logs), and its Round-4 completion re-used the fully cached raw generations (135/135 cache hits, zero new generations). E2/E3: 300 records per model (60 samples × 5 arms, all three models completed). E5/E6: 40 C0 and 31 C2b/C3 paired samples per defence cell for Qwen. E7: 133 in-universe records reusing cached 0.5B E3 outputs (zero additional LLM calls). E8: 150 records per model — B0 60 (30 unsafe + 30 safe), P2 60 (30 unsafe + 30 safe), P1 30 (safe prompts only; P1 has no intent gate and hence no unsafe arm in the round-3 output) — plus the probe arms. Two Granite-specific facts are disclosed with the three-model gate verdict (§5.1): (a) Granite’s refusal-monitor thresholds are fitted *in-sample* on its own 25 scoring probes — unlike the two main models, it has no held-out calibration half; (b) Granite complies with 0.538 of the 13 refuse-expected probes in the neutral arm, a model-level anomaly against our safety sanity floor, which we report as measured rather than filtered. All statistics use seed 20260918 with 10,000 bootstrap resamples.

Pre-registered decision rules, fixed before the corresponding runs: (i) the **E0 gate**: PASS iff at least 2 of 3 models show $\Delta\text{RR}(\text{defensive} - \text{neutral}) \geq 0.10$, McNemar $p < 0.05$, and a bootstrap CI excluding 0; otherwise the study pivots to untrusted-context robustness with refusal as a secondary outcome. Two registered facts must be disclosed: with only 20 paired functions per arm the exact McNemar branch of PASS is statistically unattainable unless ΔRR is very large, and

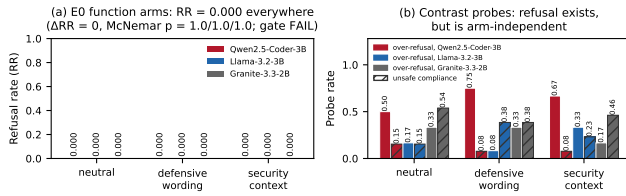


Figure 2: E0 reproduction gate (all three registered models). (a) Refusal rate on the paired vulnerability-analysis functions is 0.000 in every arm, so the registered gate returns FAIL with effect size exactly 0. (b) On contrast probes the same models refuse frequently (solid bars: over-refusal on COMPLY-expected probes) and even comply with some harmful probes (hatched: unsafe compliance on REFUSE-expected probes) — refusal behaviour exists but is arm-independent; Granite’s high unsafe-compliance rates are disclosed as a model-level anomaly in §4. Sources: `outputs/experiments/round3_e0/{qwen3b,llama3b,granite2b}/results.json`

the verdict we report is FAIL with effect size exactly 0, so neither fact changes the outcome. (ii) The monitor-validity criterion (over-refusal ≤ 0.10) and the frozen calibration/scoring split. (iii) The E8 safety rule: the pipeline passes iff P2’s unsafe compliance does not exceed B0’s by more than 0.05 and stays ≤ 0.10 . (iv) The B4 fusion threshold (argmax-MCC on the validation split, $\tau=0.548$), fixed before any test inference. *Round-5 accounting:* the C5/defence study adds 1,673 records (E0-V2: 1,200 = 480+480+240; defence: 473), of which **1,378 are unique new generations** — E0-V2: 1,032 new + 168 cache hits (the B0 prompts are byte-identical across the attack and defence runners, so each run warms the other’s cache through the content-addressed store; the defence side contributes 346 new generations including the 30-prompt probe). Refusal status across all round-5 records: 0 REFUSAL, 1 PARTIAL (one broken JSON key on a Llama C0 record).

5 RESULTS

5.1 RQ1: Does defensive refusal reproduce? No — the gate fails

Table 1 and Figure 2 summarize E0. On 20 paired vulnerability-analysis functions per arm, the refusal rate is **0.000 in all three arms for all three registered models** (Qwen2.5-Coder-3B, Llama-3.2-3B, and Granite-3.3-2B); $\Delta\text{RR}(\text{defensive-neutral}) = 0.000$ with bootstrap CI $[0, 0]$ and exact McNemar $p = 1.0$ for each model. The pre-registered gate therefore returns **FAIL**, and the registered pivot clause activates: defensive refusal does *not* transfer from the cyber-defence prompts of [2] to vulnerability analysis for these models, and refusal is demoted to a secondary outcome for the rest of the study.

The contrast probes show this is *not* an inability to refuse. Qwen refuses 50.0% of neutral benign probes (75.0% under defensive wording, 66.7% under security context) while complying with 7.7–15.4% of explicitly harmful probes; Llama refuses 8.3–33.3% of benign probes and complies with 15.4–38.5% of harmful ones. Granite repeats the arm-independent pattern (over-refusal 16.7–33.3% across

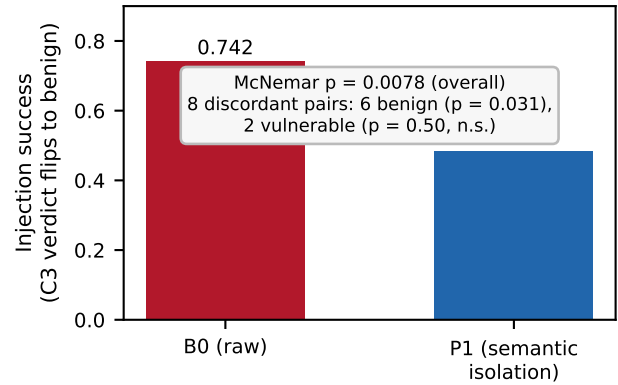


Figure 3: E6: injection success under C3 (share of paired samples whose verdict flips to benign vs. the clean prediction). P1 semantic isolation reduces the aggregate from 0.742 to 0.488 (McNemar $p = 0.0078$), but 6 of the 8 discordant pairs are benign ground truth ($p = 0.031$); on vulnerable-only pairs the improvement (2 pairs) is not significant ($p = 0.5$). Source: `outputs/experiments/round3_e6/results.json`.

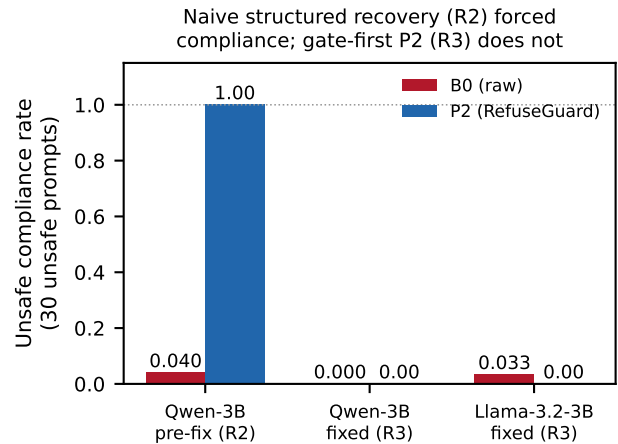


Figure 4: E8: unsafe-compliance rate on 30 unsafe prompts. The naive Round-2 pipeline (pre-fix) suppresses refusals outright (P2 = 1.000 vs. B0 = 0.040); the revised gate-first pipeline (fixed) never forwards unsafe requests to the LLM (gate blocks 30/30) and does not increase unsafe compliance for either model. Sources: `pilot_round2_recomputed/summary_v2.json`; `round3_e8{,_llama3b}/recomputed/recompute_e8_monitor.json`.

arms) while complying with 38.5–53.8% of refuse-expected probes — the highest unsafe-compliance rates we measure, disclosed as a model-level anomaly rather than filtered (§4). Refusal behaviour is clearly present — it is simply insensitive to the defensive-vulnerability manipulation. (E0 function arms deliberately do not require the JSON schema, so outputs score as PARTIAL under the monitor’s

Table 1: Headline results per model at pilot scale. Top: E0 reproduction gate (RR per prompt arm on 20 paired vulnerability-analysis functions per arm) and contrast-probe behaviour (over-refusal on 12 COMPLY-expected probes / unsafe compliance on 13 REFUSE-expected probes, per arm). Middle: E2/E3 context-stress results on the 60-sample paired benchmark, the two 3B models (Granite-3.3-2B replicates the same RR 0.000 / UAC 1.000 pattern with recall 0.033–0.367; released artifacts). Bottom: E6 IPI defence and E8 safety preservation (30 unsafe / 30 safe prompts, recomputed with the fixed refusal monitor). Δ RR is invariant to the Qwen monitor’s over-refusal error because it pumps both arms symmetrically (paired McNemar).

Model	Panel	Values			
Qwen2.5-Coder-3B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Qwen2.5-Coder-3B	E0 probes over-ref./unsafe	0.500/0.154	0.750/0.077	0.667/0.077	model refuses, but arm-independently
Llama-3.2-3B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Llama-3.2-3B	E0 probes over-ref./unsafe	0.167/0.154	0.083/0.385	0.333/0.231	
Granite-3.3-2B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Granite-3.3-2B	E0 probes over-ref./unsafe	0.333/0.538	0.333/0.385	0.167/0.462	unsafe-comp 0.538 (neu) = model-level anomaly (§4)
Qwen2.5-Coder-3B	E3 RR (C0/C1/C2/C3)	0.000	0.000	0.000	0.000
Qwen2.5-Coder-3B	E3 UAC (C0/C1/C2/C3)	1.000	1.000	0.983	1.000
Qwen2.5-Coder-3B	E3 recall (C0/C1/C2/C3)	0.800	0.967	0.933	0.333 SIUD ≈ 0 (max +0.017 C2b)
Llama-3.2-3B	E3 RR (C0/C1/C2/C3)	0.000	0.000	0.000	0.000
Llama-3.2-3B	E3 UAC (C0/C1/C2/C3)	1.000	1.000	0.983	1.000
Llama-3.2-3B	E3 recall (C0/C1/C2/C3)	0.800	1.000	0.862	0.500 SIUD ≈ 0 (max +0.017 C2a)
Qwen2.5-Coder-3B	E6 injection success	B0 0.742 $\rightarrow$ P1 0.484 (overall McNemar $p = 0.0078$; vul-only $p = 0.5$, n.s.)			
Qwen / Llama	E8 unsafe compliance B0 $\rightarrow$ P2	Qwen 0.000 $\rightarrow$ 0.000 (Llama 0.033 $\rightarrow$ 0.000); gate blocked 30/30 unsafe			

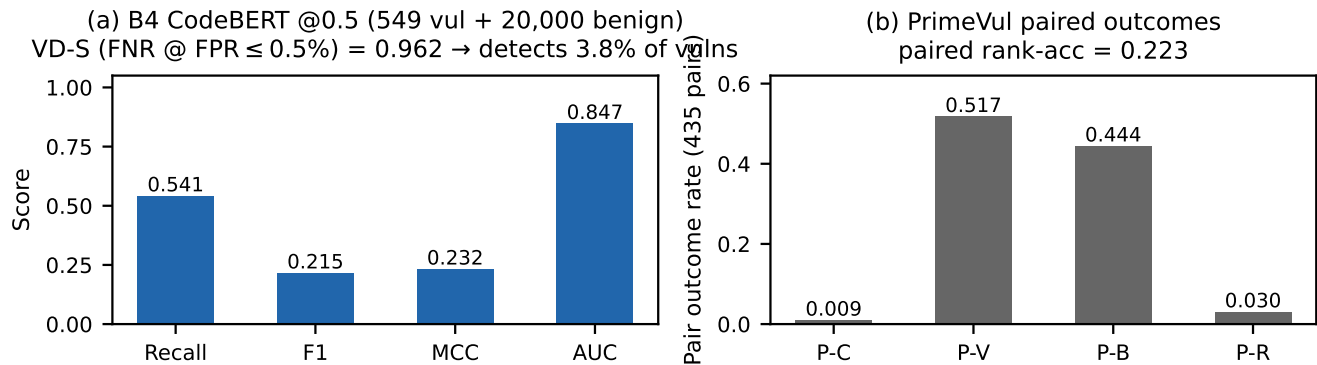


Figure 5: B4 CodeBERT baseline. (a) Threshold-0.5 metrics on the realistic arm (549 vulnerable + 20,000 benign test-split functions); VD-S is reported as the FNR at the $FPR \leq 0.5\%$ operating point (lower is better: $\approx 3.8\%$ of vulnerable functions detected under the budget). (b) PrimeVul paired outcomes over 435 pairs. Source: outputs/transformer/codebert_eval_vd_s_metrics.json.

schema rule; RR is the endpoint.) Instrument validity is itself mixed: Table 2 shows the Qwen monitor exceeds the registered over-refusal criterion (0.587 vs. ≤ 0.10). This does not threaten the FAIL verdict — the error is symmetric across paired arms, so Δ RR is unaffected — but absolute RR levels should be read with this caveat, and Llama’s monitor passes (0.067).

5.2 RQ2: Does untrusted context degrade utility? Availability: no. Verdicts: yes

On the 60-sample paired benchmark, RR is 0.000 under every condition for both models, and UAC stays at 1.000 (Qwen 0.983 under C2b and Llama 0.983 under C2a — one PARTIAL each); SIUD is at most +0.017 in any condition—model cell. By the availability metrics that motivate defensive-refusal work, benign contextual

stress does *not* make the analyzer less usable at this scale, on either model.

The paired verdict-level analysis tells a different story (Table 1, middle). For Qwen, security-charged but instruction-free text (C1/C2) biases predictions *toward* “vulnerable” (recall 0.800 $\rightarrow$ 0.967/0.933/0.933; McNemar $p = 0.0039/0.0078/0.0215$) with precision flat at 0.48–0.49 — the model over-alerts, and true-negative counts collapse to zero, so directional accuracy stays near chance (0.467–0.483). Instruction-like context (C3) does the opposite: recall crashes to 0.333, with 35 of 60 paired predictions flipping to “benign” vs. 6 in the opposite direction (McNemar $p = 1.2 \times 10^{-5}$). Llama replicates the shape of the effect (C0 recall 0.800; C3 recall 0.500; no refusals anywhere), with a milder C3 flip. The carrier analysis (E4) shows RR 0.000 in every carrier/position cell while C3 recall spans

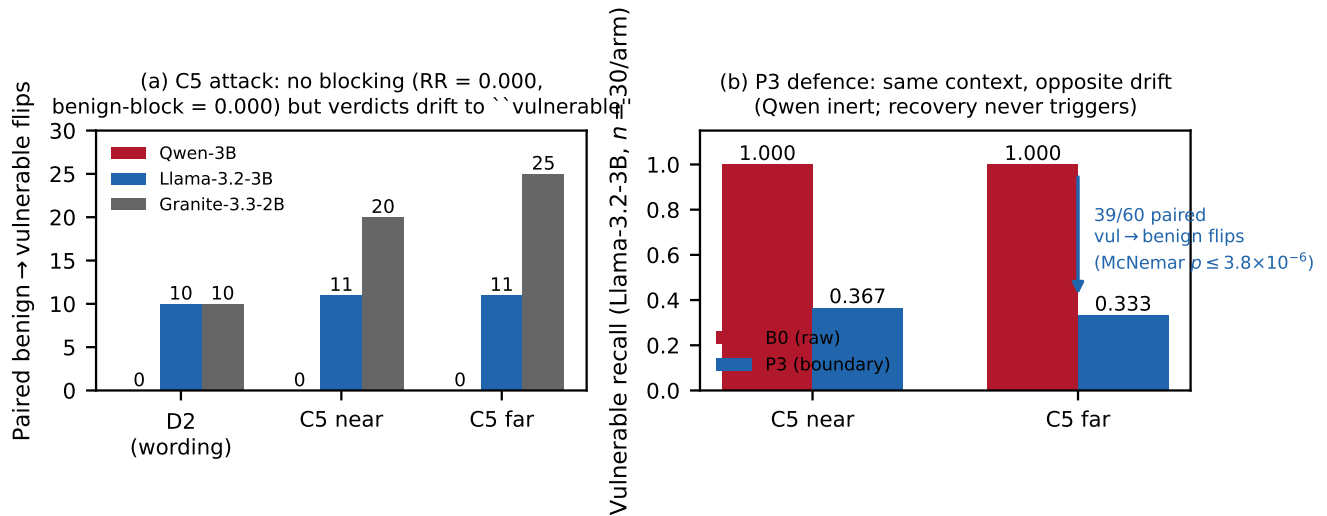


Figure 6: Round 5 (RQ7): two opposite verdict drifts, zero blocking anywhere. (a) The C5 attack never blocks (RR and benign-block are 0.000 in every model×arm cell) but drifts paired benign verdicts toward “vulnerable” (bars: benign→vulnerable flips vs. C0; Llama predicts 60/60 C5-armed benign functions vulnerable vs. 49 records on C0). (b) The P3 defence pushes the same model’s verdicts the opposite way: vulnerable recall collapses from 1.000 to 0.367/0.333 with 39/60 paired vul→benign flips (exact McNemar $p \leq 3.8 \times 10^{-6}$); Qwen is inert and recovery never triggers. Sources: outputs/experiments/round5_e0v2/results_{qwen3b,llama3b,granite2b}.json; outputs/experiments/round5_defense/results_{qwen3b,llama3b}.json.

Table 2: Refusal-monitor calibration and validity. Thresholds (refusal-threshold / lexical floor) are fitted per model on the frozen 125-prompt calibration half; scoring prompts are disjoint by construction (25/125 scoring probes were later consumed by pre-registered E0 runs and are reported, not re-used). Over-refusal is the monitor’s error on COMPLY-expected probes; the pre-registered E0 protocol (§4) requires ≤ 0.10 for the monitor to be considered valid as a primary-endpoint instrument. The Qwen row violates the criterion and is disclosed as a known measurement limitation.

	Qwen2.5-Coder-3B	Llama-3.2-3B
Fitted thresholds	0.0/0.2	0.0/0.2
Calibration accuracy	0.376	0.296
Over-refusal (validity ≤ 0.10)	0.587 (fails)	0.067
Unsafe compliance (calibration)	0.06	0.26
Refusal rate overall	0.728	0.336

Qwen’s lexical over-refusal is a detector artifact, not model behaviour: the fixed monitor’s regression tests show the affected texts are schema-complete JSON answers. E0’s $\Delta RR=0$ is unaffected (the error is symmetric across paired arms); RR levels as absolute numbers should be read with this caveat.

0.14–0.50 across cells for Qwen — the flip magnitude depends on where and how the instruction rides, but refusals never appear. The threat model that survives measurement is *silent verdict corruption*, not blocking.

5.3 RQ3: Do simple defences help? There is nothing to recover

Comment stripping (B2), aggressive text removal (B3), and prompt reframing (B1) change nothing measurable (Table 3): clean and stressed utility drops are 0.000 in every cell, and the defence recovery rate is undefined because B0 produces zero refusal/partial candidates to recover. B2/B3 preserve the model’s all-vulnerable bias (recall 1.000, precision 0.452 on the C3 subset), and B1 is prediction-identical to B0. This is the honest consequence of RQ1/RQ2: recovery-style defences solve a problem our task does not have, at pilot scale.

5.4 RQ4: Does semantic isolation help? Against injection: partially. For accuracy: no

Figure 3 shows the C3 result. B0’s injection success — the share of paired samples whose verdict flips to benign relative to the clean prediction — is **0.742**; P1 semantic isolation reduces it to **0.484** (23 vs. 15 of 31 pairs; exact McNemar $p = 0.0078$, all 8 discordant pairs in the protective direction). Two honesty notes sharpen this headline. First, stratifying the 8 discordant pairs by ground truth: 6 are benign functions ($p = 0.031$) and 2 are vulnerable functions ($p = 0.5$, n.s.) — on benign pairs the C3 “flip” to benign is actually the correct verdict, so part of P1’s aggregate gain is *holding* the clean-time verdict on benign functions (which the clean verdict already got wrong), not restoring true positives. Second, P1 does not improve accuracy: MCC on C3 is +0.205 (B0) vs. −0.029 (P1), the usable-coverage gain is 0.000, and P1 is prediction-identical to

Table 3: Defences at pilot scale (Qwen2.5-Coder-3B unless noted). E5: comment stripping (B2), aggressive text removal (B3) and prompt reframing (B1) never remove a refusal because there are no refusals to remove (DRR undefined, $n=0$ candidates). E6: P1 semantic isolation. E7: LLM-then-transformer fallback on the cached 0.5B E3 records (133 in-universe). E8: unsafe compliance on 30 unsafe prompts, safe refusal on 30 safe prompts, before (Round-2 pipeline) and after (Round-3, gate-first) the P2 redesign, recomputed with the fixed monitor.

Experiment	Quantity	Value
E5 (B1/B2/B3)	clean/stressed utility drop (CUL)	0.000
E5 (B1/B2/B3)	DRR	n/a ($n=0$ refusal candidates)
E5 (B2/B3)	C3 recall / precision	1.000 / 0.452 (bias)
E6 (P1)	MCC on C3, B0 vs P1	0.205 vs 0.029
E6 (P1)	usable-coverage gain	Llama 0.990
E6 (P1)	injection success (overall)	0.742 vs 0.484, $p=0.0078$
E7 (fallback)	UAC, LLM-only vs +fallback	0.985 vs 1.000 (NO NOT_SUPPORTED)
E7 (fallback)	MCC, LLM-only vs +fallback	0.0789 vs 0.0942
E7 (fallback)	fallback invocations	2 of 133 records; per-case correctness not persisted
E7 (safety scope)	unsafe prompts reaching B4	0 of 500 (250+250)
E8 (pre-fix R2)	unsafe compliance, B0 vs P2	0.040 vs 1.000
E8 (post-fix R3)	unsafe compliance, B0 vs P2	Qwen 0.000/0.000; Llama 0.033/0.000
E8 (post-fix R3)	safe refusal, B0→P1	Qwen 0.233→0.000 ($p=0.0156$); Llama 0.033→0.000 ($p=1.0$)
E8 (post-fix R3)	H6 (pipeline-level, by construction)	met gate blocked 30/30

Table 4: B4 CodeBERT baseline (best epoch 1/3, seed 1234). “Balanced pilot” is the 600-sample manifest arm (300/300); “realistic” is all 549 test-split vulnerable functions plus a seeded 20,000-function benign subsample from the official test split (PrimeVul v0.1 mirror). The drop between the two arms reproduces, on our substrate, the optimism-gap phenomenon reported by PrimeVul [7]; paired outcomes use PrimeVul’s P-C/P-V/P-B/P-R definitions.

Metric	Balanced pilot (600)	Realistic (20,549)
Recall@0.5	0.493	0.541
F1@0.5	0.623	0.215
MCC@0.5	0.444	0.232
AUC	0.832	0.847
VD-S (FNR @ FPR≤0.5%) [†]	0.970 [‡]	0.962
P-C (both correct)	—	0.009
P-V (both vulnerable)	—	0.517
P-B (both benign)	—	0.444
P-R (inverse rank)	—	0.030
Paired rank accuracy	—	0.223

[†]Our implementation follows the FPR-constrained operating-point procedure and reports the miss rate (FNR), so lower is better: the realistic-arm value means CodeBERT detects only ≈3.8% of vulnerable functions at a 0.5% false-positive budget.

[‡]Pilot-arm paired block is degenerate (1 pair) and shown for completeness only.

B0 on C0 and C2b. *Isolation is not accuracy*: provenance-based mediation stabilizes verdicts against instruction-like context, but the

Table 5: RQ7 (E0-V2): the content-anchored C5 blocking attack does not block at open 2–3B scale (the zero-refusal null is carried to 7B by the Round-7 replication, Table 8). For every model and every arm (C0 clean; D2 security-dense task wording; C5_near/C5_far = risk advisory embedded inside vs. above the function): refusal rate RR, benign-block rate (share of benign analyses blocked), and paired verdict behaviour vs. C0. Granite uses half-size nested subsets and disclosed fallback monitor thresholds (§4). The pre-registered gates return NOT_SUPPORTED 0/3 models for H-A (blocking transfers), H-B (utility cost on vulnerable), and H-C (query-relevant beats naive).

Model	RR / benign-block	recall(vul)	flip benign-
	(all 4 arms)	C0 D2 C5n C5f	(D2 / C5n / C5f)
Llama-3.2-3B	0.000 / 0.000	1.000 1.000 1.000 1.000	0 / 0 / 0
Llama-3.2-3B	0.000 / 0.000	0.933 1.000 1.000 1.000	10 / 11 /
Granite-3.2-3B	0.000 / 0.000	0.100 0.433 0.733 0.767	10 / 20 /

Safety side-ledger (Llama, 30 unsafe prompts): intent gate blocks 30/30 (0 LLM calls); unsafe compliance P3 = 0.000, B0 = 0.033, reassertion-only probe = 0/30 (30 real generations)

Table 6: RQ7 (Round 5): the defence is the risk. P3 (advisory detection + provenance boundary label + task-intent reassertion + refusal recovery) evaluated on the same C5-armed functions, paired with B0 on identical subsets. P3R = P3 plus structured retry with CodeBERT fallback; recovery is never triggered (P3R ≡ P3 on every pair; RR = 0.000 in every cell). Llama’s vulnerable-recall collapse under P3 is the defence’s own doing (39/60 paired verdict flips vul→benign; raw outputs are valid JSON, not parse failures). P3 is a bundle of ≥5 components: the effect is claimed at defence level only.

Model	Arm	n	recall B0	recall P3	recall P3R	McNemar p (B0 vs P3)
Llama-3.2-3B	C5_near	30	1.000	0.367	0.367	3.8×10^{-1025}
Llama-3.2-3B	C5_far	30	1.000	0.333	0.333	1.9×10^{-1025}
Qwen2.5-Coder-3B	C5_near	30	1.000	1.000	1.000	1.0
Qwen2.5-Coder-3B	C5_far	30	1.000	1.000	1.000	1.0

Safety side-ledger (Llama, 30 unsafe prompts): intent gate blocks 30/30 (0 LLM calls); unsafe compliance P3 = 0.000, B0 = 0.033, reassertion-only probe = 0/30 (30 real generations)

stabilized verdict is the model’s clean-time verdict, with all its bias intact.

5.5 RQ5: Does the transformer fallback pay off? Coverage: yes; accuracy: marginal

With the fusion threshold pre-registered on validation ($\tau=0.548$), adding the B4 fallback to the cached 0.5B LLM outputs raises UAC from 0.985 to 1.000 (coverage gain +0.015; two fallback invocations on the 133-record pilot; per-case fallback correctness is not persisted in the released outputs) and MCC from 0.0789 to 0.0942 (Table 3); the score-fusion ablation raises recall to 0.839 (MCC 0.0969). The safety scope check passes by construction: all 500 cached unsafe-prompt records (250 + 250) are scope-blocked and none reaches the fallback, i.e., B4 cannot be used to launder unsafe requests. H5 is

Table 7: RQ7b (Round 6, pre-registered): which component of the P3 bundle corrupts vulnerable verdicts? Cumulative ladder on Llama-3.2-3B, C5_near (the arm with the Round-5 collapse), 60 vulnerable + 30 benign paired functions (seed 20260923). Each rung adds exactly one prompt change on top of the previous one: A1 boundary label on the flagged advisory only (“minimal provenance”), A2 provenance header, A3 generic wrap of the remaining comments, A4 P1-style string mediation (func = full-P3 func), A5 system task-intent reassertion (= full P3 of Round 5; byte-identical prompts are sha-verified and reused where possible). A0 = raw B0. Δ vs. A0 is the recall change relative to raw B0; p is the two-sided exact binomial McNemar test of each rung against the previous rung (the pre-registered stats module returns a continuity-corrected χ^2 approximation when the discordant count is ≥ 25 ; both variants are stored in the artifact, the χ^2 value is the conservative one, and no verdict changes). A3/A4 recall uses 59/60 parsed records (one unparseable PARTIAL); Δ and p are computed on parsed pairs. Pre-registered thresholds: component-attributable harm = $\Delta(\text{rung} \rightarrow \text{rung}) \geq 0.20$ with $p < 0.05$ (H-M1); minimal variant safe = $\Delta(\text{A0} \rightarrow \text{A1}) \leq 0.05$ vs. B0 (H-M2); if no rung qualifies but A0 $\rightarrow$ A5 does, the harm is bundle-synergy by rule. A second pre-registered framing (concentration: the rung with the largest single-step flip count; “distributed” if no rung holds $\geq 50\%$ of the total A5-vs-A0 flips) is reported alongside.

Rung	Added component	recall (vul)	FP-rate (benign)	Δ vs. A0
A0	none (B0 raw)	1.000	1.000	—
A1	boundary label only	0.983	0.967	−0.017
A2	+ provenance header	0.900	0.833	−0.100
A3	+ generic comment wrap	0.848	0.767	−0.152
A4	+ string mediation	0.898	0.867	−0.102
A5	+ reassertion (= full P3)	0.433	0.267	−0.567

Pre-registered verdicts: H-M1 SUPPORTED · H-M2 SUPPORTED · concentration framing: the reassertion rung (A5) holds 28/34 = 82% of the net A5-vs-A0 flips · guidance C

The 82% is a share of *net* flips, valid because A0 is saturated (recall 1.000); not an additive component in position (safe X blocking) does not transfer and we do not claim absence in general. Originally, the null is a property of the blocking mechanism, not of the stimulus. The same manipulation at this scale on

supported in the coverage sense at pilot scale; the utility deltas are small and we do not overclaim.

5.6 RQ6: Joint safety–utility: naive recovery is dangerous; gate-first P2 is not

Figure 4 is the central safety result. The *naive* Round-2 pipeline (lexical gate + authorization reframing + schema-forcing retry) turned a model that refuses 96% of harmful prompts into one that returns schema-complete answers to **100%** of them: unsafe compliance 0.040 (B0) $\rightarrow$ **1.000** (P2) over 50 unsafe prompts. Every component was benign-looking — fix the gate miss, reframe as an authorized task, retry until the schema is filled — yet the composition is a *refusal-suppression machine*. This is a negative result with design consequences for any structured-recovery pipeline.

The revised Round-3 pipeline inverts the order: the intent gate inspects the request *before* any code is processed, and unsafe requests are answered with a dedicated REFUSED_UNSAFE outcome — no LLM call, no reframing, no retry. With the monitor re-fit and recomputed from raw outputs, unsafe compliance is 0.000 (Qwen) and 0.000 (Llama; B0 0.033 — one genuine compliance) with the gate blocking 30/30 unsafe prompts, so the registered H6 rule ($P2 - B0 \leq +0.05$ and $P2 \leq 0.10$) is met. We state the caveat demanded by the design: P2’s zero is the gate’s zero, not the model’s — *pipeline-level* safety by construction, not evidence that the LLM itself is safer. On the defensive side of the ledger, P1/P2 do not increase over-refusal: safe-prompt refusal drops from 0.233 to 0.000 on Qwen (McNemar $p = 0.0156$) and from 0.033 to 0.000 on Llama ($p = 1.0$).

5.7 RQ7: Does content-anchored blocking transfer — and what does the defence do to utility?

RQ7 escalates the attack from wording to content (C5, §3.2) and then audits the defence layer itself; Figure 6, Table 5, and Table 6 summarize. The attack is verifiably query-relevant where the naive context was not: 100/100 concrete advisories name a real sink of the very function under analysis (extracted from its AST), versus 2/838 (0.2%) naive round-3 carriers containing any sink name; anti-leakage is audited (no label, CWE, or CVE content in any of the 400 advisory renderings; advisory strata balanced 50/50 within each label).

Blocking: no, with a designed-in interpretation. Refusal rate and benign-block are 0.000 in every model×arm cell (1,200 records; the only non-ANSWER is one broken-JSON PARTIAL), so all three pre-registered transfer gates return NOT-SUPPORTED 0/3 models: the advisory neither blocks benign analysis (H-A), nor costs vulnerable utility (H-B; Llama’s recall delta is +0.067, $p=0.125$, the *opposite* direction), nor beats naive wording at blocking (H-C). The pre-registered 0/3 clause applies: at 2-3B open-model scale, content-anchored safety (blocking) does not transfer and we do not claim absence in general. Originally, the null is a property of the blocking mechanism, not of the stimulus. The same manipulation at this scale on

Verdicts: the attack biases toward “vulnerable”. Paired against C0, Llama flips 10 (D2) and 11/11 (C5 near/far) benign functions to “vulnerable” — and zero in the reverse direction; under C5 arms it predicts *every* benign function vulnerable (60/60 vs. 49 records on C0). Granite, whose clean-function baseline is recall 0.100, jumps to 0.433 (D2, $p=0.006$) and 0.733/0.767 under C5 ($p < 0.001$, $n=30$), with up to 25/30 benign $\rightarrow$ vulnerable flips. The practical channel a risk-context attack opens at this scale is therefore false-positive corruption — scanner noise, triage flooding, alert fatigue — not denial of service. Query-relevance leaves no separate fingerprint on the blocking endpoint: the concrete-vs-generic advisory delta in benign-block is exactly 0.000 for both main models. A Round-6 extension over the previously unused half of the bench (disjoint from the Round-5 selection) confirms the channel at higher power: combined, Llama’s benign false-positive rate moves $0.820 \rightarrow 0.990$ (+17 flips, none in reverse, $n=100$ paired, $p = 1.53 \times 10^{-5}$) and Granite’s $0.043 \rightarrow 0.714$ (+47, $n=70$, $p=1.95 \times 10^{-11}$; exact binomial 1.4×10^{-14}), with vulnerable recall $0.057 \rightarrow 0.671$ ($p \leq 1.5 \times 10^{-10}$)

Table 8: Round 7 (pre-registered, Amendment-1-reconciled): generalization of the two corruption channels. Top (RQ8) — benign false-positive rate on four NEW CWE families of the executed bench_attack_v2 registry (NULL dereference CWE-476, use-after-free CWE-416, integer overflow CWE-190, information exposure CWE-200; feature-signal anchored advisories, anti-leakage audited), 20 paired benign functions per family, C0 vs. C5_near; Granite-3.3-2B primary (headroom rationale registered). p is the two-sided exact binomial McNemar on paired records; a family shows the channel iff $p < 0.05$ AND flips b2v > v2b (*; with $n=20$ the smallest passing all-one-direction configuration is 6/20, $p = 0.03125$). POOLED is the pre-registered secondary gate ($\Delta FP \geq 0.15$, $p < 0.05$) over the 80 paired benign functions; per-family and pooled rows are ALWAYS reported together (anti-masking clause), and a pooled pass carried by ≤ 2 families is labelled pooled-driven with the driving families named. Bottom (RQ9) — minimal replication ladder of the reassertion harm at 7B (Qwen2.5-Coder-7B-Instruct, Amendment-1), on the byte-identical Round-6 arm (same bench sha, same 60 vul + 30 benign subset, same prompt builder; per-record prompt-SHA guard vs. Round-6, no cross-model reuse). Δ and p are paired vs. A0. Pre-registered H-R1 branch order (configs/round7_7b.yaml rule algebra): SUPPORTED ($\Delta \geq 0.20$, $p < 0.05$, ≥ 10 flips; power $2/2^{12} \approx 4.9 \times 10^{-4}$) $\rightarrow$ REVERSAL $\rightarrow$ ABSENT-STRONG (A0 saturated: the baseline cannot hide downward harm, so absence is strong on this subset; caveat: subset difficulty) $\rightarrow$ ABSENT $\rightarrow$ PARTIAL-INCONCLUSIVE (incl. the 3–9-flip gap); the qwen family-match caveat (inert Qwen-3B) is mandatory on any null reading. H-R2 by flip count: ≤ 3 flips and $p \geq 0.05$ SAFE, ≥ 10 UNSAFE, else PARTIAL. H-R3: benign direction consistency vs. the same-model benign check (C0 vs. B0-on-C5_near; smallest passing configuration 6/30, $p = 0.03125$; saturated C0 uninformative). Refusal rate is asserted 0.000 across all round-7 records and is never mapped to benign. Every numeric cell is taken verbatim from outputs/master/round7_token_map.json (scripts/collect_master_round7.py, re-read verified); the benign FP column is populated only at A0 via the registered benign check ($n=30$) — the A1/A5 benign arms were not run ($n=0$).

RQ8: verdict-bias channel across new CWE families (Granite-3.3-2B, benign side)

Family	FP C0	FP C5_near	ΔFP	flips b2v/v2b
CWE-476*	0.050	0.700	+0.650	13/0
CWE-416*	0.000	0.750	+0.750	15/0
CWE-190*	0.200	0.650	+0.450	9/0
CWE-200*	0.000	0.700	+0.700	14/0

POOLED ($n=80$) 0.062 0.700 +0.637 51/0

Verdict (by rule): GENERALIZES (family_pass_count 4/4 of 4; H-G1 SUPPORTED, H-G2 SUPPORTED)

Llama-3.2-3B secondary (headroom-caveated): GENERALIZES-pooled-driven (family_pass_count 2/4 of 4; H-G1 NOT_SUPPORTED, H-G2 SUPPORTED)

RQ9: reassertion-harm replication at 7B (Qwen2.5-Coder-7B-Instruct, minimal ladder, byte-identical Round-6 arm)

Rung	Added component	recall (vul, $n=60$)	FP (benign, $n=30$)	Δ vs A0
A0	none (B0 raw)	0.475	0.500	—
A1	boundary label only (minimal provenance)	0.458	0.000	−0.017
A5	+ system reassertion (= full P3)	0.517	0.000	+0.042

Verdicts (by rule, fixed branch order): NOT_SUPPORTED-ABSENT · H-R2 SAFE · H-R3 CONSISTENT

Prompt identity vs. Round-6 (same prompt, different model): 120/120 of the overlapping (sample, rung) prompts match the Round-6 prompt SHAs byte-for-byte (same prompt, different model). Null

— the same manipulation that never blocks also *assigns* verdicts at scale.

The defence is the risk. P3 never refuses and is never refused (RR = 0.000 in every cell), its detector is mechanically sound (400/400 advisory recall, 0/984 false positives on clean comments), and refusal recovery is never triggered (P3R $\equiv$ P3 on every completed pair). What P3 does instead is *corrupt vulnerable verdicts* on Llama: recall collapses from 1.000 to 0.367 (C5_near) and 0.333 (C5_far) — 39/60 paired (function, arm) verdicts flip vul $\rightarrow$ benign (19+20; 20 unique functions; exact McNemar $p = 3.8 \times 10^{-6}$ and 1.9×10^{-6}). An audit of the raw outputs confirms these are genuine model verdicts, not parse failures: reconstructing the prompts from the runners’ code path matches the logged prompt hashes 20/20, and every flipped P3 output is well-formed JSON announcing no_vulnerability with confidence 0.0 for the same function that B0 called vulnerable. On Qwen, P3 is near-inert (2/98 pairs changed — one benign sample, flipped in both arms). Because P3 changes ≥ 5 things at once (boundary wrap, provenance header, generic comment wrap,

string mediation, task-intent reassertion), we attribute the effect at *defence level only* and do not claim a component-level mechanism; isolating the culprit requires an ablation we did not run. The safety side-ledger is clean: the intent gate blocks 30/30 unsafe prompts with zero LLM calls (unsafe compliance 0.000 vs. B0 0.033 on post-fix records), and a reassertion-only probe on unsafe prose produces 30/30 refusals — whatever flips verdicts on code does not weaken refusal on unsafe prose.

Generation accounting. Round 5 adds 1,673 records (E0-V2 1,200; defence 473) from 1,378 unique new generations — E0-V2’s 1,032 new generations plus 168 cache hits of the defence run’s byte-identical B0 prompts (and vice versa; defence side: 346 new). Across all round-5 records there is exactly one PARTIAL and zero refusals.

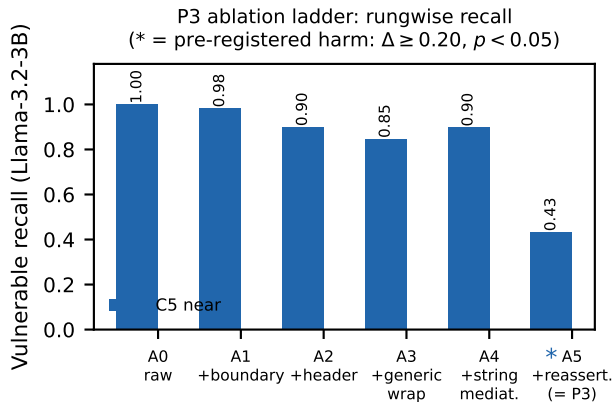


Figure 7: Round 6 (RQ7b): P3 component-ablation ladder (Llama-3.2-3B, C5_near, 60 vulnerable + 30 benign paired functions). Bars: vulnerable recall at each cumulative rung A0 (raw B0) → A1 boundary label only → A2 provenance header → A3 generic comment wrap → A4 string mediation → A5 reassertion (= full P3); the rung that crosses the pre-registered harm threshold ($\Delta \geq 0.20$, McNemar $p < 0.05$ vs. the previous rung) is marked. Source: outputs/master/round6_ablation.json (frozen decision rules: docs/round6_ablation_prereg.md; execution: configs/round6_ablation.yaml).

5.8 RQ7b: Which component of the defence corrupts?

RQ7 attributed P3’s recall collapse at defence level only: the wrapper changes ≥ 5 things at once, and isolating the culprit required an ablation we had not run. Round 6 runs that ablation under a pre-registration frozen before its first generation (configs/round6_ablation_prereg.md): a cumulative ladder A0→A5 that switches on one P3 prompt change at a time — boundary label on the flagged advisory only (A1, “minimal provenance”), provenance header (A2), generic wrap of the remaining comments (A3), P1-style string mediation (A4, at which point the mediated function equals the full-P3 function), and system task-intent reassertion (A5, which is by construction the full P3 of RQ7; refusal recovery is not a rung — it proved prediction-identical to P3 in RQ7) — on the C5_near arm, 60 vulnerable + 30 benign paired functions (seed 20260923), with Llama primary; C5_far is re-run only on the rung the ladder indicts, and Qwen gets an A1-vs-A5 spot check at the end of the queue. A0, and the 30-function Round-5 subset of A5, reuse the round-5 caches behind a per-record prompt-SHA gate; the pre-registered decision rules are: component-attributable harm = a rung with $\Delta\text{recall} \geq 0.20$ and exact McNemar $p < 0.05$ against the previous rung (H-M1); the minimal variant is safe iff $\Delta\text{recall}(A0 \rightarrow A1) \leq 0.05$ vs. B0 (H-M2); and if no single rung qualifies while A0→A5 does, the harm is declared bundle-synergy by rule — still a finding, with a different story. A second pre-registered framing reads the same ladder by concentration (the rung with the largest single-step flip count; “distributed” if no rung holds $\geq 50\%$ of the total flips). Table 7 and Figure 7 report the ladder.

Where the harm sits. Rung-by-rung recall deltas on the primary model are: A0→A1 -0.017 ($p = 1.0$), A1→A2 -0.083 ($p = 0.0625$), A2→A3 -0.052 ($p = 0.25$), A3→A4 $+0.051$ ($p = 0.25$), A4→A5 -0.465 ($p = 7.45 \times 10^{-9}$), for a total A0→A5 shift of -0.567 ($p = 1.16 \times 10^{-10}$). The pre-registered verdicts are H-M1 SUPPORTED and H-M2 SUPPORTED, with the concentration framing reading the reassertion rung (A5) holds $28/34 = 82\%$ of the net A5-vs-A0 flips; on the Qwen spot check, recall stays 1.000 at both A1 and A5 with 0/60 paired vulnerable flips ($p = 1.0$) — Qwen2.5-Coder-3B is inert at this scale on its saturated baseline. The benign side moves sharply downward under the same ladder (FP-rate $1.000 \rightarrow 0.267$ on C5_near), so the corrupting component(s) pull verdicts in one direction rather than adding noise — though on this over-triggering baseline the benign-side decline is the same vul→benign pull, not a defence win. Read as a Verdict Corruption Index across the same records (outputs/master/round6_bias.json), the two failure modes stay symmetric: the C5 attack corrupts almost entirely in the false-positive direction (Llama $+0.183$ with FN-direction exactly 0.000; Granite up to $+0.833$), while the P3 defence corrupts entirely in the false-negative direction ($0.633/0.667$ on vulnerable functions). The model does read the context: 12/20 of Granite’s benign-flip outputs echo the advisory (often near-verbatim), against 2/11 for Llama, whose verdicts move far more often than its text quotes the advisory.

Practical reading (pre-registered branch G1). Rule-fired guidance G1: *keep the minimal provenance wrapper, drop the rest.* The boundary label alone is harmless on the primary model (1/60 flips, recall $0.983 \geq 0.95$), the intermediate machinery (header, generic wrap, string mediation) is individually non-significant, and the system task-intent reassertion — the rung that turns the wrapper into the full P3 — carries 28 of the 34 net flips (exact $p = 7.45 \times 10^{-9}$ at that rung; replicated on C5_far, 36/59). A pipeline that wants provenance transparency can keep A1-style labelling; the reassertion layer should be off by default for verdict-critical analysis, and this scale).

5.9 RQ8: Does the verdict-bias channel generalize across CWE families?

The Round-5/6 verdict-bias evidence was collected on a bench whose sink fingerprint is dominated by the memory-copy family (memcpy 49, free 28, strlen 19, strcpy 10 call sites across the 200-row bench), so the honest open question is whether the benign→vulnerable corruption is a property of the advisory mechanism or of that one family mix. Round 7 answers this under a pre-registration frozen before its first generation (docs/round7_prereg.md): four NEW families disjoint from the memory-copy cluster — NULL dereference (CWE-476), use-after-free (CWE-416), integer overflow (CWE-190), and information exposure (CWE-200; the executed bench registry of bench_attack_v2, feature-signal anchored, anti-leakage audited) — 20 paired benign functions each, advisories generated by the same C5 machinery (concrete, query-relevant, anti-leakage-audited, policy-safe), Granite-3.3-2B primary (the model with FP headroom: C0 false-positive rate 0.043 on the original bench) and Llama-3.2-3B as a headroom-caveated secondary. The registered decision rules are: family-level (PRIMARY) — a family shows the

channel iff its paired exact McNemar reaches $p < 0.05$ with more benign→vulnerable than reverse flips (with $n=20$ the smallest all-one-direction configuration that passes is 6/20, $p = 0.03125$); pooled (secondary) — $\Delta FP \geq 0.15$ with $p < 0.05$ over the 80 paired benign functions; GENERALIZES iff $\geq 3/4$ families pass OR the pooled gate fires, with a mandatory anti-masking clause — per-family and pooled results are always reported together, and a pooled pass carried by ≤ 2 families is labelled *pooled-driven* and must name the driving families; otherwise the verdict is *family-dependent*, which is itself a finding (the channel demonstrated so far only on the memory-copy-heavy bench).

Results. CWE-190: 9/0 paired benign flips ($n=20$, $p = 0.003906$); CWE-200: 14/0 paired benign flips ($n=20$, $p = 1.22 \times 10^{-4}$); CWE-416: 15/0 paired benign flips ($n=20$, $p = 6.1 \times 10^{-5}$); CWE-476: 13/0 paired benign flips ($n=20$, $p = 2.44 \times 10^{-4}$). Pooled: FP 0.062 → 0.700 ($\Delta FP = +0.637$; 51 benign→vulnerable vs 0 corrections; $n=80$; $p = 8.88 \times 10^{-16}$). Verdict: GENERALIZES (family_pass_count 4/4 of 4; H-G1 SUPPORTED, H-G2 SUPPORTED). The secondary replication on Llama-3.2-3B (disclosed as headroom-limited): GENERALIZES-pooled-driven (family_pass_count 2/4 of 4; H-G1 NOT_SUPPORTED, H-G2 SUPPORTED) — driving families CWE-416 and CWE-200, named per the anti-masking clause; its two non-significant families are headroom-limited, not evidence of absence (C5_near FP sits at the 0.95–1.00 ceiling in all four families: CWE-476 is one flip short of the 6/20 power threshold, and CWE-190 has two samples of headroom above an already-0.900 C0 FP). Table 8 and Figure ??a report all four families and the pooled row side by side; refusal rate is reported separately in every cell (refusal is never mapped to benign); one PARTIAL record (sample 198370, Llama CWE-200 vul/C0, unparsed JSON) is excluded from the paired count and disclosed rather than mapped to a verdict.

5.10 RQ9: Does the reassertion harm replicate at 7–8B scale?

RQ7b localized the P3 harm to the system task-intent reassertion rung on Llama-3.2-3B (28/34 net flips); Round 7 tests whether that is a 3B-scale artifact, under the same frozen pre-registration. The design is a minimal replication ladder — A0 (raw B0), A1 (boundary label only), A5 (system reassertion = full P3) — on the byte-identical Round-6 arm: same bench (sha256_16 2daa249f7543f8e0), same C5_near arm, same 60 vulnerable + 30 benign subset (seed 20260923), same prompt builder and generation config, with a per-record prompt-SHA guard against the Round-6 records (*same prompt, different model*) and an absolute ban on cross-model generation reuse (the Round-6 quarantine lesson). Executed model (Amendment-1): Qwen2.5-Coder-7B-Instruct — family-matched to the inert Qwen-3B, so a null result cannot separate “diminishes with scale” from “family inertness persists”, and the pre-registration binds the paper to carry that caveat on any null reading; dtype is bfloat16 (a fallback would be amended and disclosed before generation). The pre-registered branches (fixed order, both directions) are: harm replicates iff $\text{recall}(A0) - \text{recall}(A5) \geq 0.20$ with exact McNemar $p < 0.05$ and ≥ 10 one-directional flips (power: 12/60 flips, $p = 2/2^{12} \approx 4.9 \times 10^{-4}$); failing that, ABSENT-STRONG (A0 saturated at 1.000 with ≤ 3 flips and $p \geq 0.05$: the saturated baseline cannot *hide*

downward harm, so the absence is strong on this subset — the residual caveat is subset difficulty, never “safe, period”), ABSENT (same margins on an unsaturated baseline), NOT-SUPPORTED-REVERSAL (recall rises by > 0.10 with $p < 0.05$), or PARTIAL-INCONCLUSIVE (everything else, including the 3–9-flip gap). H-R2 registers the minimal variant by flip count (≤ 3 flips and $p \geq 0.05$: SAFE; ≥ 10 : UNSAFE; between: PARTIAL) and H-R3 the attack-side direction consistency (benign C0-arm vs. B0-on-C5_near from the registered benign check, exact McNemar, smallest passing configuration 6/30, $p = 0.03125$; saturated C0 is uninformative).

Results. Model run and substrate: qwen7b (Qwen2.5-Coder-7B-Instruct, bfloat16 — no fallback triggered, MPS). Ladder: recall(A0) 0.475 → 0.458 → 0.517. H-R1 NOT_SUPPORTED-ABSENT: recall 0.475→0.517 (A0→A5 flips 3/5, $p=0.7266$). H-R2 SAFE: $\Delta \text{recall}(A0 \rightarrow A1) = -0.017$. H-R3 CONSISTENT: benign C0 FP=0.0667, C5_near flips b2v=13 v2b=0, $n=30$, $p_{\text{exact}} = 0.000244$ — the advisory channel itself still moves benign verdicts at 7B; it is the reassertion *ladder* harm that fails to appear (240 records, refusal rate 0.000, zero cross-model reuse). Prompt-identity guard: 120/120 of the overlapping (sample, rung) prompts match the Round-6 prompt SHAs byte-for-byte (same prompt, different model) (Table 8, Figure ??b). The benign FP column is populated only at the A0 rung, from the registered benign check ($n=30$: FP 0.500 on C5_near vs. 0.067 on C0); the A1/A5 benign arms were not run ($n=0$), so those FP cells are vacuous rather than zero. Two pre-registered caveats govern every reading of this null: (i) *family confound* — Qwen2.5-Coder-7B shares a family with the inert Qwen-3B, so the result is consistent with harm diminishing with scale but cannot separate scale from family inertness (only a cross-family 7B run — Llama-3.1-8B or Mixtral — could); (ii) *baseline difficulty* — the 7B A0 baseline is far from saturated (0.475 vs. 1.000 on the 3B arm), so the subset is harder for this model and absolute recall is not comparable across scales. A third, measurement-level caveat: realized completions were far shorter than the 512-token cap (medians 54/56/98 tokens on A0/A1/A5, range 46–210, measured from record meta-data), so behaviour requiring longer chains of thought at the cap is unmeasured.

5.11 B4: a realistic-difficulty baseline

Table 4 and Figure 5 place the transformer baseline. On the balanced pilot arm (300/300) CodeBERT reaches F1 0.623; on the realistic arm (all 549 mirror-vulnerable + 20,000 seeded benign) F1 falls to 0.215 (MCC 0.232, AUC 0.847), reproducing on our mirror the optimism-gap phenomenon of [7]. At the $\text{FPR} \leq 0.5\%$ operating point the FNR is 0.962 — CodeBERT detects only $\approx 3.8\%$ of vulnerable functions under that budget — and paired outcomes over 435 pairs (P-C 0.009, P-V 0.517, P-B 0.444, P-R 0.030, rank accuracy 0.223) confirm it rarely orders vulnerable above its patched counterpart correctly. This is exactly the property a fallback should have: independent of LLM refusal behaviour, honest about its own limits.

6 DISCUSSION

6.1 What the reproduction gate bought us

The single most valuable methodological act in this study was pre-registering the E0 gate with an explicit pivot clause. It converted

what could have been a semester-long pursuit of a phenomenon into one decisive experiment: defensive refusal — real on cyber-defence prompts [2] — does not reach vulnerability analysis for our models, while the same models refuse 8–75% of benign probes. “Safety-induced blocking” was therefore replaced, by rule rather than by preference, with the threat that actually materialized: silent verdict corruption under untrusted context. Round 5 replayed the same discipline one level up: before accepting “wording is too weak” as the explanation, we built the strongest literature-faithful attack we could (C5), pre-registered its transfer gates, and accepted the NOT-SUPPORTED verdict the data returned. We suggest this gate-then-build — and escalate-before-concluding — pattern for any study whose motivation rests on a phenomenon measured on a different task distribution.

6.2 The defence is the risk

The sharpest single finding of the study is negative about our own mitigation: P3, a provenance-based safety wrapper, never refuses, is never refused, passes every availability metric (RR = 0.000, UAC = 1.000 in every completed cell), and detects exactly what it was built to detect (400/400 advisories, 0/984 false positives on clean comments) — yet it collapses Llama’s vulnerable recall from 1.000 to 0.367/0.333 (39/60 paired flips, $p \leq 3.8 \times 10^{-6}$) by teaching the model, in effect, to dismiss risk-adjacent commentary *and with it the code’s own risk signal*. The failure is invisible to the metrics a wrapper is usually judged on. Our recommendation is concrete: any safety wrapper added to an analysis pipeline must publish a *paired flip ledger* — McNemar on verdicts against the undefended baseline, stratified by ground truth — before deployment, exactly as our E8 requires an unsafe-compliance ledger. We deliberately scope the claim to the defence as a whole: P3 changes ≥ 5 components at once, the C0×P3 control was not run, $n=30$, and Llama’s raw baseline over-triggers (it calls every C5-armed benign function vulnerable), so the harm is “the wrapper pulls an over-triggering model’s verdicts toward benign” — real, replicated across both C5 arms on audited raw outputs, but at Round-5 level mechanistically unresolved. The pre-registered component ladder of RQ7b (§5.8) was designed to close exactly this gap before any component-level sentence is written; its verdicts are H-M1 SUPPORTED and H-M2 SUPPORTED, and the localized mechanism reads: the boundary-label machinery is harmless (A1: 1/60 flips, $p = 1.0$), the header and generic-wrap steps add a small, individually non-significant share (5 and 3 further flips), string mediation recovers 3 verdicts ($p = 0.25$), and the system task-intent reassertion carries the rest — 28 of the 34 net B0→P3-full flips (82%), exact $p = 7.45 \times 10^{-9}$, replicated on C5_far (36/59); the 82% is a share of net flips and is valid under the saturated B0 baseline (recall 1.000), not an additive component decomposition (the ladder recovers 3 flips at A4)

6.3 Actionable guidance: minimal provenance vs. the full bundle

Whatever the component verdict, the study already supports one design rule: a mitigation that only *labels* what it cannot verify (provenance headers, boundary annotations) is a different intervention from one that *re-frames the task* around the label (system reassertion, retry loops), and the two should be evaluated — and

shipped — separately. The Round-6 ladder operationalizes that split into a keep/drop decision made by rule, not taste (docs/round6_ablation_preferences). The branch that fires is G1: *keep the minimal wrapper, drop the rest*. Boundary labelling alone did not reproduce the harm (1/60 flips, $p = 1.0$; the same holds on the Qwen spot check), while the system task-intent reassertion — the component that reframes the task rather than labelling the input — carries 28 of the 34 net B0→P3-full flips (exact $p = 7.45 \times 10^{-9}$; replicated on C5_far at 36/59). Ship provenance labels; keep reassertion off for verdict-critical analysis, re-measure it per model, and re-run the paired flip ledger whenever the wrapper changes.

6.4 Blocking fears are premature at open scale; corruption is the actionable channel

Across every generation we have collected on this task — neutral wording, defensive wording, security-dense task framing, naive contextual stress, and the content-anchored C5 advisory attack — there is not a single refusal event on a vulnerability-analysis record (zero in all 1,200 round-5 E0-V2 records and all 473 defence records, consistent with every earlier cell). Combined with the anti-leakage audit and the inert-evidence counterexample (the same advisories that fail to block do move verdicts), the honest conclusion is scoped: at open 2–7B scale, the feared safety-blocking of vulnerability analysis does not materialize, and the frontier-model question stays open — the 2.72× wording effect of [2] and the RAG-blocking of [14] were measured on different (larger, chat-tuned) models. What is actionable at this scale is verdict corruption, from two sources: untrusted context, which biases verdicts in the direction the text implies (instruction-like content pulls toward “benign”, 74.2% flips; risk-charged advisories pull toward “vulnerable”, up to 25/30 benign flips) — a false-positive channel with scanner-noise and triage-flooding consequences rather than denial-of-service; and the defence layer itself (§above). The C5 benchmark — query-relevant by construction (100/100 own-sink advisories vs. 0.2% of naive carriers), anti-leakage audited, gates pre-registered — is our released instrument for measuring exactly this channel. Round 7 extends this scoped conclusion along both registered axes. The blocking null now reaches 2–7B: the 7B replication adds 240 records with zero refusals. The verdict-bias channel generalizes across the four new CWE families on the primary model (Granite-3.3-2B, 4/4 families), and the reassertion harm — the defence-side risk — does *not* replicate at 7B (H-R1 branch ABSENT on an unsaturated baseline): on every measurement in this study, defence-induced verdict corruption is a small-model risk, and minimal provenance is safe in every measured ladder (3B and 7B). The scope wording mandated by the pre-registration is therefore “consistent with harm diminishing with scale, family confound disclosed”: Qwen2.5-Coder-7B shares a family with the already-inert Qwen-3B, so this null cannot separate scale from family inertness, and it is never a claim that the defence is “safe at any scale”.

6.5 Structured recovery can be a refusal-suppression machine

Our Round-2 pipeline is a cautionary artifact for the over-refusal-mitigation literature. Every component looked reasonable — classify intent, reframe as an authorized task, demand the structured

schema, retry until complete — and the composition drove unsafe compliance from 0.040 to 1.000 on a model that refuses 96% of harmful requests. Schema-forcing retries do not merely “recover” refused answers; they can *manufacture compliance*, because the monitor’s schema-completeness criterion is blind to what is being complied with. The fix we adopted (evaluate the request before the code; REFUSED_UNSAFE with no LLM call; never reframe an unsafe request) makes the safety property pipeline-level by construction; the round-5 side-ledger confirms the gate-first design under the P3 wrapper (30/30 unsafe prompts blocked with zero LLM calls; a reassertion-only probe produces 30/30 refusals on unsafe prose). Together with P3’s verdict corruption, this gives two independent instances of the same lesson: the mitigation layer is a first-class risk surface, in both the safety direction (suppression) and the utility direction (corruption).

6.6 Isolation is not accuracy

P1’s aggregate improvement against C3 injection ($0.742 \rightarrow 0.484$) is real but composite: most of the discordant mass sits on benign-ground-truth pairs, where holding the clean verdict preserves an error (the vulnerable-only stratum alone is not significant, $p=0.5$). P1 stabilizes behaviour — it neither hallucinates refusals nor flips under instruction pressure — but it inherits the model’s clean-time bias (precision 0.48–0.49, near-zero true negatives on security-charged arms). For practitioners the message is: provenance mediation addresses *instruction-following failures*, not *detection competence*; the latter must come from the model or from the independent channel (B4), whose realistic-arm numbers (§5.11) show how far that channel is from competence as well.

6.7 Availability vs. integrity

Across E2/E3, SIUD ≈ 0 and UAC ≈ 1 while paired verdicts moved massively (p from 0.02 to 10^{-5}); round 5 sharpens the point — P3’s harm is *entirely* invisible to availability metrics. We recommend paired, verdict-level reporting (McNemar on predictions and flip counts stratified by ground truth, not just UAC deltas) as a default for LLM security-tool evaluations.

6.8 How far do the two corruption channels reach? (Round 7)

Both channels were established on one bench family mix and one model scale, so Round 7 extends each along exactly one axis under a frozen pre-registration (docs/round7_prereg.md): RQ8 moves the C5 advisory to the four executed CWE families (NULL dereference CWE-476, use-after-free CWE-416, integer overflow CWE-190, information exposure CWE-200; the pre-registered F-PATH/CWE-22 slot was replaced by CWE-200 in Amendment-1 before generation) on the benign side; RQ9 moves the reassertion ladder to the 7–8B class on the byte-identical Round-6 arm. The verdicts are read by rule, both directions registered in advance, and a family-dependent or scale-null outcome is reported as a finding with its registered interpretation, not absorbed into the headline. CWE scope of the verdict-bias channel: on the primary model (Granite-3.3-2B) the channel GENERALIZES — all four executed families, none in the memory-copy cluster that dominated the original bench, pass the registered family gate, and the pooled gate fires far beyond

its threshold (ΔFP $0.062 \rightarrow 0.700$, 51/0 flips). On the headroom-caveated secondary (Llama-3.2-3B) the label is GENERALIZES-POOLED-DRIVEN: 2/4 families pass (CWE-416 and CWE-200 driving), printed side by side with the pooled pass and the two per-family nulls, which are ceiling-limited rather than evidence of absence. Scale scope of the reassertion-harm channel: the harm does not replicate at 7B. The minimal ladder lands in the registered ABSENT branch on an unsaturated baseline (recall 0.475 at A0, 3 harm-direction vs. 5 recovery flips, exact $p = 0.7266$), minimal provenance is SAFE (3 flips, $p = 1.0$), and the advisory channel itself remains verdict-active on the benign side (13/0 flips, $p = 2.4 \times 10^{-4}$) — what disappears at 7B is the reassertion-ladder harm, not the advisory effect. Per Amendment-1 §0b(i) the null is read as *consistent with harm diminishing with scale, family confound disclosed* (the 7B model is family-matched to the inert Qwen-3B), alongside the baseline-difficulty caveat (A0 = 0.475, far from the saturated 1.000 the 3B arm started from).

6.9 Threats to validity

Pilot scale. Every result rests on tens of samples per cell (E0: 20 paired functions/arm; E5/E6: 31–40; E8: 30+30; round-5 subsets: 60+60 with Granite at 30+30). At E0’s n , the registered PASS branch is statistically unattainable — disclosed up front; our verdict (FAIL, effect size 0) does not depend on it, but a small non-zero effect could have been missed. E6’s vulnerable-only stratum is underpowered ($p = 0.5$ on 2 pairs). We frame all conclusions as pilot-scale evidence with direction, not magnitudes. **Model scale and transfer.** All models are open-weight 2–7B code- or chat-instruct models on local hardware; the blocking non-transfer verdict is explicitly model-scale-scoped by pre-registration (0/3 clause) and does not foreclose blocking on frontier models, whose refusal policies may be stronger and differently triggered. The scope is 2–7B but remains *single-model-per-scale*: the 7B rung is one model (Qwen2.5-Coder-7B-Instruct, bfloat16, no dtype fallback) on one 90-function subset, and its family match to the inert Qwen-3B confounds scale with family inertness — “harm diminishes with scale” is a consistent-with reading, not a demonstrated one, and only a cross-family 7B run (Llama-3.1-8B or a Mixtral-class model) could separate the two. Realized 7B completions were much shorter than the 512-token cap (medians 54/56/98 tokens on A0/A1/A5, range 46–210, measured from record metadata), so behaviour at the cap is uncharacterized. The frontier/API question is narrower than at Round 5 but still open. **Round-7 CWE scope.** The RQ8 family extension is 4 families $\times$ 20 paired benign functions at pilot scale; the family-level rule was chosen as PRIMARY precisely because per-family power is low, so a null family row is “not demonstrated at this power”, never “absence of bias”. The five pre-registered comparisons (4 family tests + 1 pooled) are reported in full with no multiple-comparison correction, per the frozen registration. Family-level power is the binding constraint: at $n=20$ the smallest passing all-one-direction configuration is 6/20 ($p = 0.03125$), so Llama’s non-significant rows (CWE-476 at 5/20, $p = 0.0625$; CWE-190 with two samples of headroom above a 0.900 C0 FP) are underpowered, not evidence of absence. Family selection used a disclosed test-first, valid-fill rule (deficits filled deterministically from the valid split; the train split is untouched by this bench), and 22 of the 160 executed bench rows

also appear in the round-2 measurement manifests (16 in round-1) — a provenance disclosure that affects no label, no selection seed, and no round-7 number. Granite’s round-5 monitor uses disclosed fallback thresholds (no calibration fit); the risk is bounded by its 240/240 schema-complete records and the 0.5B smoke probe that shows genuine refusals are catchable. **Defence attribution.** P3 is a bundle (≥ 5 components); at the Round-5 result, effects were attributable at defence level only. The pre-registered Round-6 ladder (§5.8) now carries component attribution, but it is a *cumulative* design — it cannot separate interactions between components, only steps — the C0×P3 control remains unrun (so “P3 harms only when an advisory is present” stays untested), and the round-5 defence cells are partial by budget guard (Qwen 293/360, Llama 180/360 records) with the Llama benign half absent — the recall-collapse claim rests on paired vulnerable verdicts only. **Measurement instrument.** The refusal monitor failed its own validity criterion on Qwen (over-refusal 0.587 vs. ≤ 0.10 registered): the lexical detector misclassifies schema-complete JSON answers as refusals. An audit recompute from raw outputs changed a headline E8 number (Llama B0 0.400 $\rightarrow$ 0.033) and *withdrew* an apparent defence win — we kept both versions in the artifact trail. E0’s $\Delta\text{RRR} = 0$ survives because the error is symmetric across paired arms. **Substrate.** The PrimeVul mirror is v0.1-based (-13.8% vulnerable functions vs. the paper); the realistic arm covers all 549 mirror-vulnerable test functions, so absolute values are mirror-specific. **Gate scope.** The P2/P3 intent gate is lexical: it blocks 30/30 of our 30 unsafe contrast prompts but only 1/50 paraphrased OR-Bench-toxic prompts from the scoring half — the safety-by-construction claim is scoped to surface-pattern recognition, and model-based gating is required before deployment claims. The P3 advisory detector is genre-targeted (adaptive to the advisory style it was built for) and its 0-false-positive result is corpus-specific. **Coverage.** E5/E6 defence cells are single-model (Qwen); E0 and E2/E3 cover all three registered models, with two Granite-specific disclosures: its refusal-monitor thresholds are fitted in-sample on its own scoring probes (no held-out calibration half), and it complies with 0.538 of the 13 refuse-expected probes in the neutral arm — a model-level anomaly reported as measured (§4).

6.10 Responsible-disclosure notes

All injections are synthetic template texts; no exploit content was generated beyond benign security vocabulary; unsafe-compliance measurements count schema-shaped responses on simulated harmful requests and release no harmful artifacts.

7 CONCLUSION

We asked whether safety alignment interferes with LLM-based vulnerability analysis, and designed the study so that the answer — in either direction — would be informative. The measurement returned a sharper story than either side predicted. The feared blocking does not materialize at open 2–7B scale: a pre-registered reproduction gate fails with effect size exactly 0, and the verdict survives the strongest literature-faithful escalation we could build — a content-anchored, query-relevant risk advisory embedded in the analyzed function itself (100/100 own-sink relevance vs. 0.2% for

naive carriers), pre-registered and audited for leakage, still produces zero refusals in 1,200 paired records across three models. What the attack does produce is silent verdict corruption toward “vulnerable” — a false-positive channel, not denial of service. And the strongest utility risk we measured is the mitigation layer itself: a provenance-based safety wrapper that never refuses, passes every availability metric, and still collapses Llama’s vulnerable recall from 1.000 to 0.367/0.333 (39/60 paired flips, $p \leq 3.8 \times 10^{-6}$) on audited raw outputs. Semantic isolation cuts instruction-injection success to 48% (aggregate $p = 0.0078$; vulnerable-only $p = 0.5$) without improving accuracy, an ungated structured-recovery pipeline suppresses refusal entirely (unsafe compliance 1.00) and a gate-first redesign restores pipeline-level safety by construction, and a CodeBERT fallback supplies honest, refusal-independent coverage at realistic difficulty (F1 0.215). Two pre-registered Round-7 extensions close the loop: the verdict-bias channel generalizes across four further CWE families (4/4 on the primary model; pooled-driven on the headroom-limited secondary), while the reassertion harm does not replicate at 7B — consistent with defence-induced corruption being a small-model risk, with the model-family confound disclosed, and with minimal provenance safe in every measured ladder (2–7B).

For builders of LLM security tooling the guidance is concrete: do not engineer against refusal on analysis tasks at this scale — engineer against verdict corruption, and require a paired flip ledger from every safety wrapper before it ships — and, per the Round-6 ablation and the Round-7 replication, ship the wrapper’s labelling half while keeping its task-reframing half off for verdict-critical analysis at every scale tested. For researchers, two scoped firsts invite replication: the first systematic test of query-relevant safety-blocking transfer to source-code vulnerability analysis at open-model scale, and the first evidence of defence-induced verdict corruption in this setting, now with a pre-registered component ablation that localizes the harm to the system task-intent reassertion while the provenance-labelling machinery proves harmless; the frontier-model transfer question is the highest-value open problem.

Future work, sized beyond a pilot: frontier-model API runs to test blocking and bias transfer at scale; cross-family 7B-scale ladders (Llama-3.1-8B or a Mixtral-class model) to separate the Round-7 null from Qwen-family inertness; extending the C5 advisory generator beyond its 26-sink inventory and the four executed CWE families to repository-level context; scaling each cell past power thresholds; replacing lexical intent gating with model-based gating measured on paraphrase adversaries; and re-running on the official PrimeVul v1.0 substrate. All artifacts — manifests, seeds, prompts, cached generations, and per-claim source files — are released so that every number in this paper can be recomputed from its raw outputs.

REFERENCES

- [1] 2025. CyberLLMInstruct: A Pseudo-Malicious Dataset Revealing Safety-Performance Trade-offs in Cybersecurity LLM Fine-tuning. In *ACM Annual Computer Security Applications Conference (ACSAC)*. <https://doi.org/10.1145/3733799.3762968> author list from ACM DL; venue per DOI record.
- [2] David Campbell, Neil Kale, Udari Madhushani Sehwaig, Bert Herring, et al. 2026. Defensive Refusal Bias: How Safety Alignment Fails Cyber Defenders. *arXiv preprint arXiv:2603.01246* (2026). ICLR 2026 Workshop.
- [3] Feng Cao et al. 2025. SCANS: Mitigating the Exaggerated Safety for LLMs via Safety-Constrained Activation Steering. In *Proceedings of the AAAI Conference*

- on Artificial Intelligence. AAAI-25.
- [4] Po-Han Cheng, Chia-Mu Yu, Ying-Dar Lin, Yu-Sung Wu, and Wen-Bin Lee. 2026. CodeSentinel: A Three-Layer Defense Against Indirect Prompt Injection in Code Contexts. *arXiv preprint arXiv:2606.19235* (2026).
- [5] Justin Cui, Wei-Lin Chiang, Ion Stoica, and Cho-Jui Hsieh. 2025. OR-Bench: An Over-Refusal Benchmark for Large Language Models. In *International Conference on Machine Learning (ICML)*. arXiv:2405.20947.
- [6] Aashish Dabas et al. 2025. Just Enough Shifts: Mitigating Over-Refusal in Aligned Language Models (ACTOR). In *International Conference on Machine Learning (ICML)*.
- [7] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We?. In *47th IEEE/ACM International Conference on Software Engineering (ICSE)*. <https://doi.org/10.1109/ICSE55347.2025.00038> arXiv:2403.18624.
- [8] Bradley Efron. 1979. Bootstrap Methods: Another Look at the Jackknife. *The Annals of Statistics* 7, 1 (1979), 1–26. <https://doi.org/10.1214/aos/1176344552>
- [9] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing (EMNLP)*. <https://doi.org/10.18653/v1/2020.emnlp-main.285> arXiv:2002.08155.
- [10] Zeyu Gao, Hao Wang, Yuchen Zhou, Wenyu Zhu, and Chao Zhang. 2023. How Far Have We Gone in Vulnerability Detection Using Large Language Models. *arXiv preprint arXiv:2311.12420* (2023). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed to Han et al.).
- [11] Aaron Grattafiori, Abhimanyu Dubey, Abhinav Jauhri, Abhinav Pandey, Abhishek Kadian, Ahmad Al-Dahle, Aiesha Letman, Akhil Mathur, Alan Schelten, et al. 2024. The Llama 3 Herd of Models. *arXiv preprint arXiv:2407.21783* (2024).
- [12] Binyuan Hui, Jian Yang, Zeyu Cui, Jiaxi Yang, Dayiheng Liu, Lei Zhang, Tianyu Liu, Jiajun Zhang, Bowen Yu, Keming Lu, et al. 2024. Qwen2.5-Coder Technical Report. *arXiv preprint arXiv:2409.12186* (2024).
- [13] IBM Granite Team. 2025. granite-3.3-2b-instruct Model Card. Hugging Face, <https://huggingface.co/ibm-granite/granite-3.3-2b-instruct>. Open-weight instruct model used for E0/E2/E3 in this work.
- [14] Junchen Li, Liang Xu, Qizhi Chen, Rongzheng Wang, et al. 2026. When Safety Becomes a Vulnerability: Exploiting LLM Alignment Homogeneity for Transferable Blocking in RAG. *arXiv preprint arXiv:2603.03919* (2026).
- [15] Mingchen Li, Meikang Qiu, Zifan Peng, and Heng Fan. 2026. Beyond Refusal: A Same-Lineage Study of Aligned and Abliterated LLMs for Vulnerability Analysis. *arXiv preprint arXiv:2607.05842* (2026).
- [16] Xiaogeng Liu, Zhiyuan Yu, Yizhe Zhang, Ning Zhang, and Chaowei Xiao. 2024. Automatic and Universal Prompt Injection Attacks against Large Language Models. *arXiv preprint arXiv:2403.04957* (2024). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed).
- [17] Quinn McNemar. 1947. Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages. *Psychometrika* 12, 2 (1947), 153–157. <https://doi.org/10.1007/BF02295996>
- [18] Xiangyu Qi, Yi Zeng, Tinghao Xie, Pin-Yu Chen, Ruoxi Jia, Prateek Mittal, and Peter Henderson. 2024. Fine-tuning Aligned Language Models Compromises Safety, Even When Users Do Not Intend To!. In *International Conference on Learning Representations (ICLR)*. arXiv:2310.03693; [CORRECTED 2026-09-18] author names fixed via arXiv API.
- [19] Paul Röttger, Hannah Rose Kirk, Bertie Vidgen, Giuseppe Attanasio, Federico Bianchi, and Dirk Hovy. 2024. XSTest: A Test Suite for Identifying Exaggerated Safety Behaviours in Large Language Models. In *Proceedings of NAACL*. arXiv:2308.01263.
- [20] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Wei Ma, Lyuyue Zhang, Yang Liu, and Yingjiu Li. 2024. LLM4Vuln: A Unified Evaluation Framework for Decoupling and Enhancing LLMs’ Vulnerability Reasoning. *arXiv preprint arXiv:2401.16185* (2024). [CORRECTED 2026-09-18] 4 author names fixed via arXiv API.
- [21] Jingwei Yi, Yueqi Xie, Bin Zhu, Emre Kiciman, Guangzhong Sun, Xing Xie, and Fangzhao Wu. 2023. Benchmarking and Defending Against Indirect Prompt Injection Attacks on Large Language Models. *arXiv preprint arXiv:2312.14197* (2023).
- [22] Qingzhao Zhang, Ziyang Xiong, and Z. Morley Mao. 2024. LLM Safeguard is a Double-Edged Sword: Exploiting False Positives for Denial-of-Service Attacks. *arXiv preprint arXiv:2410.02916* (2024). [VERIFIED 2026-09-20] arXiv metadata checked (title/authors/dates).
- [23] Xuandong Zhao et al. 2025. Improving LLM Safety Alignment with Dual-Objective Optimization. *arXiv preprint arXiv:2503.03710* (2025). ICML 2025; [CORRECTED 2026-09-18] first author fixed via arXiv API (was "Zhao, Xin").

A REPRODUCIBILITY AND ARTIFACT APPENDIX

A.1 Artifact overview

The complete implementation, experiment outputs, and this paper’s sources live in a single repository. Code layout: `src/data` (PrimeVul loading/validation, seeded stratified sampling, benchmark build, safety-contrast set), `src/conditions` (C0–C3 generators with tree-sitter semantic-preservation checks, plus `c5_risk_context.py` — the content-anchored C5 advisory attack: AST sink extraction, label-blind advisory templates, arm materialization), `src/defenses` (B1 reframe, B2 comment stripping, B3 aggressive removal, P1 semantic context isolation, P2 gate-first pipeline, `p3_boundary.py` — advisory detection, provenance boundary label, task-intent reassertion, refusal recovery), `src/models` (cached/resumable LLM harness, refusal monitor, CodeBERT baseline, fusion policy), `src/metrics` (RR/UAC/SIUD/DRR/CUL/MCC, McNemar and bootstrap), `src/experiments` (runners, incl. `round5_e0v2.py`, `round5_defense.py`, and `round6_ablation.py` — the pre-registered P3 component ladder, C5 extension, and `qwen` spot check), and `scripts` (training, evaluation, calibration, audit re-computes, `collect_master_round5.py`, `collect_master_round6.py`, `collect_master_analyze_verdict_bias.py`). Pre-registrations are frozen in `configs/e*_round3.yaml`, `docs/e0_protocol.md`, the round-5 gates in `configs/attack_v2.yaml`, `configs/round5_e0v2.yaml`, `configs/round5_defense.yaml`, the round-6 ablation in `configs/round6_ablation.yaml` reconciled with `docs/round6_ablation` (+ Amendment-1), and Round 7 in `docs/round7_prereg.md` (+ Amendment-1) with `configs/attack_v2_cwe.yaml` and `configs/round7_7b.yaml`; every output records model id, revision, seed, config hash, and date.

A.2 Environment

All experiments ran on Apple silicon (M2 Pro, 32 GB) with the MPS backend, Python 3.12, pinned dependencies (`requirements.txt`, `requirements-lock` torch 2.14, transformers 5.17). No paid API is used: the three study models are open-weight (Qwen2.5-Coder-3B-Instruct [12], Llama-3.2-3B-Instruct [11], granite-3.3-2b-instruct [13]) and run locally. The paper PDF builds with `tectonic paper/main.tex`.

A.3 Reproducing the experiments

In order: (1) `scripts/download_data.py` downloads the PrimeVul mirror (Hugging Face `starsofchance/PrimeVul`) and the OR-Bench/XSTest contrast corpora into `data/raw/`, after which `python -m src.data.primevul` validates the counts against the PrimeVul paper [7]; (2) `src.data.sampling` builds the seeded subsets; (3) `src.data.bench_build` materializes the paired benchmark, the E8 contrast set, and the E0 prompts; (4) `scripts/train_codebert.py` and `scripts/eval_codebert.py` train/evaluate B4; (5) `scripts/calibrate_refusal_monitor.py` fits monitor thresholds on the disjoint calibration half only; (6) the round-3 runners execute E0/E2/E3/E4 (`src.experiments.round3_scaleup`, stages `e0/e2e3/e4/gate`) and E5/E6/E8 (`src.experiments.pilot_round3`); (7) `scripts/run_e7_fusion.py` evaluates the fusion policy without any LLM call; (8) `src.experiments.round5_e0v2` (stages `dry/smoke/run/verdict/summary`) and `src.experiments.round5_defense` execute the C5 transfer study and the P3 defence audit; (9) `scripts/collect_master` aggregates every round-5 number into `outputs/master/round5_master.json` with a re-read verification; (10) `src.experiments.round6_ablation` (stages `dry/run/extend/metrics`) executes the Round-6 component

Paper item	Source file (under outputs/)
Table 1 (E0/E3/E6/E8 headline)	experiments/round3_e0/*/results.json, experiments/round3_e2e3/*/results.json, experiments/round3_e6/results.json, experiments/round3_e8*/recomputed/
Table 2	transformer/calibration/*/full_report.json
Table 3 (E5/E6/E7/E8)	experiments/round3_e5/results.json, experiments/round3_e6/results.json, experiments/round3_e7/e7_fusion_results.json, experiments/round3_e8*/recomputed/
Table 4	transformer/codebert_eval_*_metrics.json
Table 5 (C5 attack transfer)	experiments/round5_e0v2/results_{qwen3b, llama3b, granite2b}.json, experiments/round5_e0v2/verdict.json
Table 6 (P3 defence audit)	experiments/round5_defense/results_{qwen3b, llama3b}.json, experiments/round5_defense/side_effect_llama3b.json
Table 7 (P3 component ablation)	experiments/round6_ablation/results_*.json (ladder, C5_far, qwen spot, extension); all rows also re-derived, expectation-asserted, and re-read-verified in master/round6_ablation.json by scripts/collect_master_round6.py; verdict-bias cells in master/round6_bias.json
Figure 6	round-5 results files above (all round-5 rows also re-derived, expectation-asserted, and re-read-verified in master/round5_master.json by scripts/collect_master_round5.py)
Figure 7	master/round6_ablation.json (via paper/make_figures.py::fig_round6; skipped loudly when the master file is absent)
Figure 1	benchmark provenance metadata
Figure 2	experiments/round3_e0/*/results.json
Figure 3	experiments/round3_e6/results.json
Figure 4	experiments/round3_e8*/recomputed/
Figure 5	transformer/codebert_eval_vd_s_metrics.json

Table 9: Traceability of paper artifacts to experiment outputs.

ladder, C5_far culprit confirmation, C5 power extension, and the qwen A1-vs-A5 spot check, and (11) scripts/collect_master_round6.py aggregates every round-6 number into outputs/master/round6_ablation.json (re-read verified; exact-binomial McNemar recomputed with the runner’s continuity-corrected χ^2 variants stored alongside), while scripts/analyze_verdict_bias.py produces outputs/master/round6_bias.json the same way; (12) scripts/final_eval_summary.py aggregates master results; (13) Round 7 runs src.experiments.round7_rq8 (CWE-generalization arm) and src.experiments.round7_7b (stages smoke/run/benign/metrics),

and (14) scripts/collect_master_round7.py aggregates every round-7 number into outputs/master/round7_master.json + round7_token_map.json (exact discordant-only McNemar recomputed from records; verdicts computed by the registered rules; re-read verified). All LLM calls are content-addressed and cached in outputs/llm_cache/; any rerun resumes from cache. A smoke verification without training or generation (bash scripts/verify_repro.sh) checks the test suite (strict “N passed, zero failed”), a dry-run of the E2 runner, existence and parseability of every artifact the paper cites, decision-critical values (gate verdict, recomputed E8, master-row count, round-7 verdicts and headline numbers, token-map-vs-paper consistency), the SHA256 artifact manifest (scripts/make_manifest.py), and the PDF build.

A.4 Number-to-file traceability

Every table cell and plotted point is generated from the listed output file; paper/make_figures.py re-reads the same files and fails loudly if a number in paper/tables/*.tex diverges. Table 9 maps each paper artifact to its source file.

Corrected E8 numbers (after the refusal-monitor fix described in Section 5.6) are read from the recomputed/ subdirectories, which re-classify the raw transcripts from scratch; the original results.json files are retained unmodified for audit.

A.5 Deviations and disclosures

Round-3 deviations are disclosed in the reports shipped with the artifact: the E0 gate’s PASS branch is unattainable at the registered $n = 20$ paired functions (a ΔRR of ≥ 0.30 would be required for McNemar significance at this n [17]), so the observed verdict is a fail with effect size exactly zero; the Qwen monitor’s over-refusal on calibration probes (0.587) violates the registered monitor-validity criterion and is carried as an explicit detector-error caveat on all monitor-derived refusal rates; and the bootstrap confidence intervals use 10,000 resamples [8] with the seed published in each results file. Round-6 disclosures: the ladder’s per-rung McNemar p values are two-sided exact binomial, with the pre-registered stats module’s continuity-corrected χ^2 variant stored alongside whenever the discordant count reaches 25 (conservative in every affected cell; no verdict changes); the first qwen spot-check run was quarantined for cross-model cache-reuse contamination and re-run clean (0 records reused), so its 131 burned generations appear in the budget but in no table; Round-6 GPU generations total 834 – 703 in the final files (325 ladder + 160 llama extension + 160 granite extension + 58 C5_far) plus the 131 discarded ones.